CEH v13 AI (312-50)

Module 01: Introduction to Ethical Hacking

Exam-Focused Study Guide

Built from the official Module 01 theory video screenshots. Content labelled ADDED CONTEXT comes from outside the notes.

Table of Contents

1. Module at a Glance 5
2. Big Picture Map 7
3. Topic-by-Topic Guide 8
   - 3.1 Elements of Information Security 8
   - 3.2 Information Security Attacks: Motives, Goals, and Objectives 9
   - 3.3 Tactics, Techniques, and Procedures (TTPs) 10
   - 3.4 Classification of Attacks 11
   - 3.5 Information Warfare (InfoWar) 14
   - 3.6 What is Hacking? 15
   - 3.7 Who is a Hacker? 16
   - 3.8 Hacker Classes and Their Motivations 16
   - 3.9 Scope and Limitations of Ethical Hacking 18
   - 3.10 How AI-Driven Ethical Hacking Helps Ethical Hackers 20
   - 3.11 ChatGPT-Powered AI Tools for Ethical Hackers (and ShellGPT) 21
   - 3.12 CEH Ethical Hacking Framework (the Five Phases) 24
   - 3.13 Cyber Kill Chain Methodology 26
   - 3.14 MITRE ATT&CK Framework 28
   - 3.15 Diamond Model of Intrusion Analysis 29
   - 3.16 Information Assurance (IA) 31
   - 3.17 Continual/Adaptive Security Strategy 32
   - 3.18 Risk Management 33
   - 3.19 What is Risk? (Risk Levels and Risk Matrix) 34
   - 3.20 Cyber Threat Intelligence (CTI) 35
   - 3.21 Threat Intelligence Lifecycle 37
   - 3.22 Threat Modeling 38
   - 3.23 Incident Handling and Response (IH&R) 39
   - 3.24 Role of AI and ML in Cyber Security 40
   - 3.25 How Do AI and ML Prevent Cyber Attacks? 42
   - 3.26 Payment Card Industry Data Security Standard (PCI DSS) 43
   - 3.27 ISO/IEC Standards 44
   - 3.28 Health Insurance Portability and Accountability Act (HIPAA) 45
   - 3.29 Sarbanes-Oxley Act (SOX) 46
   - 3.30 DMCA and FISMA 47
   - 3.31 General Data Protection Regulation (GDPR) 48
   - 3.32 Data Protection Act 2018 (DPA) 50
   - 3.33 Cyber Law in Different Countries 50
4. Tool Encyclopedia 53
   - 4.1 Tools named in the screenshots 53
   - 4.2 Close alternatives the exam often places next to them 54
5. Command Sheet 56
   - 5.1 sudo su 56
   - 5.2 sgpt (ShellGPT) 57
   - 5.3 Preview commands for framework tools (ADDED CONTEXT) 59

6. Ports, Protocols, Standards and Acronyms 61
6.1 Ports and protocols linked to this module 61
6.2 Standards, laws and frameworks 61
6.3 Acronyms 62
6.4 Rare terms worth a short introduction 64
7. Attack vs Countermeasure and Look-alike Comparisons 65
7.1 Attacks and their countermeasures 65
7.2 Look-alike pairs 65
8. Exam Cheat Sheet 68
8.1 Keyword -> answer 68
8.2 Must-memorize lists 69
8.3 Numbers and defaults 69
8.4 "Pick the BEST option" rules for this module 70
9. Practice Questions 71
Answer Key 76
10. Flashcards 79
11. Glossary 81
12. Coverage Report 84
12.1 Page to section map 84
12.2 UNCLEAR items 85
12.3 Items to double check 85
12.4 Inventory confirmation 86

CEH v13 AI (312-50) Study Guide - Module 01: Introduction to Ethical Hacking

Source: 18 pages of screenshots from the official Module 01 theory videos (slides 4 to 58). Content marked "ADDED CONTEXT" comes from outside the screenshots. Items marked "verify" should be checked against current official sources.

1. Module at a Glance

Module: 01 - Introduction to Ethical Hacking (EC-Council CEH v13 AI).

What this module is (5 lines):

1. It defines information security and its five elements (CIA plus authenticity and non-repudiation).
2. It explains why and how attacks happen: motives, TTPs, attack classes, and information warfare.
3. It describes hackers: who they are, the hat colors, and what drives them.
4. It introduces ethical hacking, AI-driven hacking, and the main frameworks: CEH 5 phases, Cyber Kill Chain, MITRE ATT&CK, Diamond Model.
5. It covers security management (IA, adaptive strategy, risk, threat intelligence, threat modeling, incident response, AI/ML) and the major laws and standards.

Why it matters: Module 01 is the vocabulary of the whole exam. Every later module assumes you know the phases, the attack classes, the hacker types, and the frameworks. Many "easy marks" on the exam come from this module.

What the exam usually asks from it:

- Which security element (confidentiality, integrity, availability, authenticity, non-repudiation) is affected in a scenario.
- Which attack class (passive, active, close-in, insider, distribution) a scenario describes.
- Which hacker class fits a description (gray hat, hacktivist, script kiddie, and so on).
- Which phase of the CEH framework or Cyber Kill Chain an activity belongs to.
- Which threat intelligence type serves which audience.
- Which law or standard applies (PCI DSS for cards, HIPAA for health data, SOX for public company finance, GDPR for EU personal data).
- Order of steps: kill chain, risk management, threat intelligence lifecycle, IH&R.

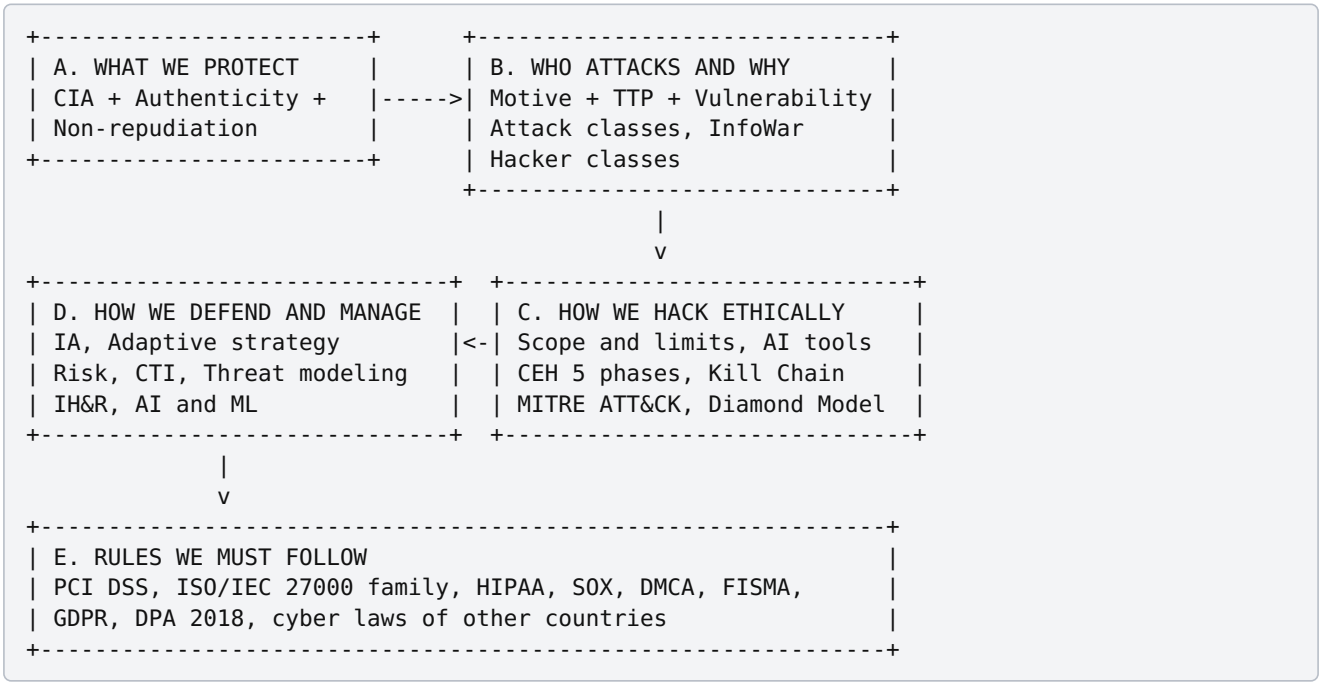
The 10 things to remember most:

1. CIA + Authenticity + Non-repudiation. Non-repudiation = sender cannot deny sending, receiver cannot deny receiving.
2. Attack = Motive (Goal) + Method (TTP) + Vulnerability.
3. Passive = watch only (sniffing). Active = change or disrupt (DoS, MITM, SQLi). Close-in = physically near. Insider = trusted person. Distribution = tampering before installation (supply chain).
4. Gray hat = finds bugs without permission. Hacktivist = cause or ideology. Script kiddie = uses others' tools. Blue hat = hired to test before release. Red hat = vigilante against black hats.

5. CEH phases: Reconnaissance -> Scanning -> Gaining Access -> Maintaining Access -> Clearing Tracks.
6. Cyber Kill Chain (7): Recon, Weaponization, Delivery, Exploitation, Installation, Command and Control, Actions on Objectives.
7. Diamond Model: Adversary (who), Capability (how), Infrastructure (what), Victim (where).
8. Threat intel types: Strategic (executives), Tactical (TTPs), Operational (specific incoming attack), Technical (IoCs).
9. Adaptive security: Protect, Detect, Respond, Predict.
10. Laws: PCI DSS (card data), HIPAA (health), SOX (2002, investors, 11 titles), GDPR (EU, 25 May 2018, 7 principles), DMCA (copyright, WIPO), FISMA (US federal systems).

2. Big Picture Map

The module moves from "what we protect" to "who attacks", then "how we hack ethically", then "how we manage and defend", and ends with "which rules we must follow".



Block	Topics in this guide	Section numbers
A. What we protect	Elements of information security	3.1
B. Who attacks and why	Motives, TTPs, attack classes, InfoWar, hackers	3.2 to 3.8
C. How we hack ethically	Scope, AI tools, frameworks	3.9 to 3.15
D. How we defend	IA, adaptive security, risk, CTI, IH&R, AI/ML	3.16 to 3.25
E. Rules	Standards and laws	3.26 to 3.33

3. Topic-by-Topic Guide

3.1 Elements of Information Security

What it is: Information security is "a state of well-being of information and infrastructure" in which the chance of theft, tampering (unauthorized change), and disruption of information and services is low or tolerable. Security is never 100 percent. The goal is to make risk small enough to accept.

The five elements are the five goals of security:

Element	Simple meaning	Typical control
Confidentiality	Only authorized people can read it	Encryption, access control
Integrity	Data is trustworthy and not changed	Hashing, checksums, change control
Availability	Systems work when authorized users need them	Backups, redundancy, anti-DoS
Authenticity	The data or message is genuine	Digital certificates, login checks
Non-repudiation	Sender and receiver cannot deny the exchange	Digital signatures, audit logs

From the slide, word for word in meaning:

- Confidentiality: information is accessible only to those authorized to have access.
- Integrity: trustworthiness of data or resources, preventing improper or unauthorized changes.
- Availability: systems that deliver, store, and process information are accessible when required by the authorized users.
- Authenticity: a communication, document, or data is genuine (quality of being genuine).
- Non-repudiation: a guarantee that the sender cannot later deny sending, and the recipient cannot deny receiving.

Analogy: A sealed bank letter. Confidentiality is the sealed envelope. Integrity is the tamper-proof seal. Availability is the post office being open. Authenticity is the bank logo you can trust. Non-repudiation is the signed delivery receipt.

How it works:

1. Identify what information needs which element (a public web page needs availability and integrity, not confidentiality).
2. Choose a control for each element (encryption for confidentiality, hashes for integrity).

3. Monitor the controls and fix gaps.

Real-world use: A hospital (who) encrypts patient records (confidentiality), hashes lab results (integrity), and keeps a backup data center (availability) because law requires it (why). Result: a ransomware attack slows them for hours, not weeks.

Tools and commands used here: None in the notes. Hashing tools (for example sha256sum) and encryption tools appear in Module 20.

Countermeasures and defense: Encryption, hashing, digital signatures, multi-factor authentication, backups, redundant systems, logging.

> **EXAM TIP:** "Cannot deny sending" = non-repudiation. "Data changed in transit" = integrity. "Website down" = availability. "Data read by outsider" = confidentiality. "Is this really from the CEO?" = authenticity.

EXAM FOCUS:

- How it is asked: a short scenario, then "which element was violated?"
- Keywords: "disclosed" or "read" -> confidentiality; "modified" or "altered" -> integrity; "unreachable" or "down" -> availability; "genuine" -> authenticity; "deny" -> non-repudiation.
- Trap: a digital signature gives integrity, authenticity, AND non-repudiation. If the question says "cannot deny", pick non-repudiation.
- Look-alike: authenticity (is it genuine) vs integrity (is it unchanged). A forged email is an authenticity problem. A real email changed in transit is an integrity problem.

Memory trick: "CIA-AN" -> "The CIA has an AN-alyst": Confidentiality, Integrity, Availability, Authenticity, Non-repudiation.

3.2 Information Security Attacks: Motives, Goals, and Objectives

What it is: An attack happens when three things meet:

```
Attack = Motive (Goal) + Method (TTP) + Vulnerability
```

- Motive (goal): why the attacker wants to attack. A motive starts from the idea that the target system stores or processes something valuable.
- Method (TTP): how they attack. Attackers use tools and techniques.
- Vulnerability: the weakness they use. It can be in the computer system or in its security policy and controls.

Analogy: A burglary needs a reason (money), a method (lock picking), and a weakness (a cheap lock). Remove any one and the burglary fails.

Motives behind information security attacks (from the slide):

1. Disrupting business continuity.
2. Stealing information and manipulating data.
3. Creating fear and chaos by disrupting critical infrastructures.
4. Causing financial loss to the target.
5. Propagating religious or political beliefs.
6. Achieving a state's military objectives.
7. Damaging the reputation of the target.
8. Taking revenge.
9. Demanding ransom.

How it works:

1. The attacker sees value in the target (motive).
2. The attacker picks tools and techniques (method).
3. The attacker finds a weakness (vulnerability) and exploits it.

Real-world use: A ransomware gang (who) targets a city council because its systems are critical and it may pay (motive), uses phishing plus ransomware (method), and exploits an unpatched VPN (vulnerability). Result: services stop and a ransom is demanded.

Countermeasures and defense: You usually cannot remove the motive. You can block methods (security controls, training) and remove vulnerabilities (patching, hardening). This is why defense focuses on vulnerabilities.

EXAM FOCUS:

- How it is asked: "An attack consists of which three components?" or "Which component can the defender most directly control?"
- Keywords: "goal", "TTP", "weakness".
- Trap: some options swap "Threat" for "Motive". The slide formula is Motive + Method + Vulnerability.
- Look-alike: the risk formula (Risk = Threat x Vulnerability x Impact) is different from the attack formula.

Memory trick: "MMV" -> "My Monkey Vanished": Motive, Method, Vulnerability.

3.3 Tactics, Techniques, and Procedures (TTPs)

What it is: TTPs are the patterns of activities and methods associated with specific threat actors (attackers) or groups of threat actors.

Term	Slide definition	Simple meaning
Tactics	Strategy adopted by the attacker from beginning to end	The overall game plan (the why)

Term	Slide definition	Simple meaning
Techniques	Technical methods used to achieve intermediate results	The specific tricks (the how)
Procedures	Systematic approach used by threat actors to launch an attack	The exact step-by-step recipe

Analogy: A football team. Tactics = "we will attack down the left wing". Techniques = "use a long pass and a cross". Procedures = "player 7 runs at minute 10, player 4 passes on signal".

How it works:

1. Analysts observe many attacks by one group.
2. They record the strategy (tactics), the tricks (techniques), and the exact sequences (procedures).
3. Defenders use these TTPs to detect the group again, even if it changes IP addresses or malware hashes.

Real-world use: A SOC team (who) learns that a threat group always gets initial access with spear phishing (technique), aims for credential theft (tactic), and runs a fixed PowerShell sequence (procedure). They write detection rules for that sequence. Result: the next intrusion is caught early.

> **ADDED CONTEXT:** TTPs are the top of the "Pyramid of Pain" (David Bianco). Blocking hashes or IPs is easy for attackers to evade. Blocking TTPs forces attackers to change how they work, which is the most "painful" for them. MITRE ATT&CK (section 3.14) is a catalogue of TTPs.

EXAM FOCUS:

- How it is asked: "Which TTP element describes the overall strategy?" -> Tactics. "Which describes technical methods for intermediate results?" -> Techniques.
- Trap: procedures are the most detailed level, not the most general.
- Look-alike: TTPs vs IoCs. IoCs are artifacts (hashes, IPs). TTPs are behaviors.

Memory trick: Tactics = Target plan, Techniques = Tricks, Procedures = Precise steps. General -> specific: T, T, P.

3.4 Classification of Attacks

What it is: CEH sorts attacks into five classes by how the attacker interacts with the target.

Class	Simple meaning	Slide examples
Passive	Watches traffic, changes nothing	Sniffing, eavesdropping
Active	Changes data or disrupts service	DoS, MITM, session hijacking, SQLi
Close-in	Attacker is physically close	Eavesdropping, shoulder surfing, dumpster diving
Insider	Trusted person misuses access	Device theft, keyloggers, backdoors, malware
Distribution	Tampering before installation	Hardware or software changed at source or in transit

Details from the slide:

- Passive attacks do not tamper with data. They intercept and monitor network traffic and data flow.
- Active attacks tamper with data in transit or disrupt communication or services, to bypass or break into secured systems.
- Close-in attacks are performed in close physical proximity to the target system or network, to gather, modify, or disrupt access to information. The slide lists them as social engineering examples.
- Insider attacks use privileged access to violate rules or intentionally cause a threat to the organization's information or systems.
- Distribution attacks happen when attackers tamper with hardware or software prior to installation, at its source or in transit.

Key word definitions:

- Sniffing: capturing network packets to read them.
- Eavesdropping: secretly listening to a conversation or communication.
- MITM (man-in-the-middle): the attacker sits between two parties and relays or changes their messages.
- Session hijacking: taking over a logged-in session (for example, stealing a session cookie).
- SQL injection: inserting database commands into input fields.
- Shoulder surfing: watching someone type a password or PIN.
- Dumpster diving: searching rubbish for useful documents.
- Keylogger: software or hardware that records keystrokes.
- Backdoor: a hidden way back into a system that bypasses normal login.

Analogy: Passive = listening at the door. Active = breaking the door. Close-in = standing behind you at the ATM. Insider = the house cleaner stealing. Distribution = the lock was already broken when the shop sold it.

How it works:

1. Passive: attacker places a sniffer on the network and records traffic.
2. Active: attacker sends crafted traffic or input that changes data or stops services.
3. Close-in: attacker goes near the target (office, bin, desk).
4. Insider: an employee abuses rights they already have.
5. Distribution: attacker changes a product in the factory, in shipping, or in the software update channel.

Real-world use: A supplier's update server (who) is hacked and a backdoor is added to a signed update (distribution attack). Thousands of customers install it because they trust the vendor (why). Result: wide compromise. This pattern matches real supply chain attacks such as SolarWinds in 2020.

Countermeasures and defense:

- Passive: encryption (TLS, VPN), switched networks, sniffing detection.
- Active: firewalls, IDS/IPS, input validation, patching, rate limiting.
- Close-in: privacy screens, shredding, physical security, visitor control.
- Insider: least privilege, separation of duties, monitoring, background checks, offboarding.
- Distribution: code signing checks, trusted suppliers, tamper-evident packaging, hash verification, software bill of materials (SBOM).

> **ADDED CONTEXT:** Common attack vectors (paths into a target) that CEH lists in this module include cloud computing threats, advanced persistent threats (APT), viruses and worms, ransomware, mobile threats, botnets, insider attacks, phishing, web application threats, and IoT threats (verify full list against courseware).

EXAM FOCUS:

- How it is asked: scenario -> "what type of attack is this?"
- Keywords: "monitor", "capture", "no change" -> passive; "modify", "disrupt", "inject" -> active; "physical", "nearby", "trash", "over the shoulder" -> close-in; "employee", "privileged" -> insider; "before installation", "in transit", "factory" -> distribution.
- Trap: eavesdropping appears in both passive and close-in. If it happens on the network, it is passive. If the attacker is physically nearby listening, it is close-in.
- Look-alike: insider vs close-in. An insider is trusted. A close-in attacker is only near.
- Passive attacks are hard to detect because nothing changes.

Memory trick: "PACID" -> Passive, Active, Close-in, Insider, Distribution. "PACID acid burns everything."

3.5 Information Warfare (InfoWar)

What it is: Information warfare is the use of information and communication technologies (ICT) to gain a competitive advantage over an opponent. ICT means computers, networks, phones, and the internet.

- Defensive information warfare: all strategies and actions designed to defend against attacks on ICT assets.
- Offensive information warfare: attacks against the ICT assets of an opponent.

Defensive warfare (from slide)	Offensive warfare (from slide)
Prevention	Web application attacks
Deterrence	Web server attacks
Alerts	Malware attacks
Detection	MITM attacks
Emergency preparedness	System hacking
Response	(list ends)

The slide diagram shows defensive warfare on one side, offensive warfare on the other, the Internet in the middle, and "INFO SECURITY" as the wall between them.

```
DEFENSIVE WARFARE    +------------+    OFFENSIVE WARFARE
Prevention        I  |            |  I  Web Application Attacks
Deterrence        N  |            |  N  Web Server Attacks
Alerts            F  |  INTERNET  |  F  Malware Attacks
Detection         O  |            |  O  MITM Attacks
Emergency Prep.      |            |     System Hacking
Response             +------------+
                  INFO SECURITY wall on both sides
```

Analogy: A castle. Defensive warfare is walls, guards, alarms, and fire drills. Offensive warfare is the enemy's catapults and spies.

How it works:

1. Defender prevents (blocks), deters (discourages), alerts, detects, prepares for emergencies, and responds.
2. Attacker uses web app attacks, web server attacks, malware, MITM, and system hacking against the opponent.

Real-world use: During a geopolitical conflict, a state (who) defaces government websites and spreads malware (offensive) to weaken morale (why). The target country runs national CERT alerts and incident response (defensive). Result: services restored, attacks attributed.

> **ADDED CONTEXT:** Martin Libicki described seven forms of information warfare: command and control warfare (C2W), intelligence-based warfare, electronic warfare, psychological warfare, hacker warfare, economic warfare, and cyberwarfare. Older CEH versions listed these; they may still appear in questions (verify for v13).

EXAM FOCUS:

- How it is asked: "Deterrence and detection are part of which type of information warfare?" -> defensive.
- Trap: "deterrence" sounds aggressive, but it is defensive.
- Keyword: "against the ICT assets of an opponent" -> offensive.

Memory trick: Defensive list in order: "Please Don't Alert Dad, Every Rabbit": Prevention, Deterrence, Alerts, Detection, Emergency preparedness, Response.

3.6 What is Hacking?

What it is: From the slide:

1. Hacking refers to exploiting system vulnerabilities and compromising security controls to gain unauthorized or inappropriate access to a system's resources.
2. It involves modifying system or application features to achieve a goal outside of the creator's original purpose.
3. Hacking can be used to steal and redistribute intellectual property, leading to business loss.

Analogy: Using a butter knife to open a locked drawer. The knife was not made for that purpose (feature used outside its original purpose), and you open something you should not.

How it works:

1. Find a weakness (vulnerability).
2. Bypass or break a security control.
3. Gain access or make the system do something unintended.

Real-world use: A criminal (who) exploits a web server bug to copy source code (intellectual property) and sells it (why). Result: the company loses its competitive advantage.

> **ADDED CONTEXT:** Ethical hacking uses the same tools and techniques as hacking, but with the owner's written permission, a defined scope, and the aim of finding and fixing weaknesses. The ethical hacker reports findings and does not cause damage. Permission (authorization) is the single difference that matters legally.

EXAM FOCUS:

- Keywords: "unauthorized access", "exploiting vulnerabilities", "outside the original purpose".
- Trap: the difference between hacking and ethical hacking is permission, not the tools.

Memory trick: Hacking = "E-M-S": Exploit, Modify, Steal.

3.7 Who is a Hacker?

What it is: From the slide:

1. An intelligent individual with excellent computer skills who can create and explore computer software and hardware.
2. For some hackers, hacking is a hobby, to see how many computers or networks they can compromise.
3. Some hackers want to gain knowledge or to probe and do illegal things.
4. Some hack with malicious intent, such as stealing business data, credit card information, social security numbers, email passwords, and other sensitive data.

Analogy: A locksmith. The same skill can open your door when you are locked out, or rob your house.

Real-world use: A teenager (who) starts by exploring systems for fun (hobby), later joins a forum and steals game account passwords (malicious intent). Result: the same skill set turns criminal.

EXAM FOCUS: Questions rarely ask this slide directly. It sets up the hacker classes table in 3.8. Remember that "hacker" by itself means a skilled person; intent decides the class.

Memory trick: Hacker = "Skill + Intent". Skill makes a hacker. Intent picks the hat color.

3.8 Hacker Classes and Their Motivations

What it is: CEH groups hackers into classes by skill, intent, and permission. The slides give a table of eleven classes with background, motivation, cyber activity, and potential targets.

Part 1 (slide 13):

Class	Background	Motivation	Typical activity	Targets
Script kiddies	Inexperienced, often young; use pre-made tools	Thrill, recognition, fun	Simple DDoS, defacing	Small sites, games, forums

Class	Background	Motivation	Typical activity	Targets
White hat	Cybersecurity professionals	Better security, salary, reputation	Pen tests, vuln assessments	Companies, government
Black hat	Extraordinary computing skills	Money, data theft, harm	Malware, phishing, ransomware	Banks, people, enterprises
Gray hat	Between ethical and unethical	Recognition, curiosity, money	Find vulns without permission	Various, high-profile orgs
Hacktivists	Politically or socially driven	A cause, social justice	DDoS, defacing, data leaks	Government, corporations
State-sponsored	Trained, work for governments	National security, espionage	Espionage, sabotage, theft	Other nations, corporations

Part 2 (slide 14):

Class	Background	Motivation	Typical activity	Targets
Cyber terrorists	Extremists using cyber attacks	Fear, political or ideological	Attack infrastructure, propaganda	Critical infrastructure
Corporate spies	Hired to gather competitor intel	Money, competitive advantage	Industrial espionage, spying	Competitor companies
Blue hat	Hired temporarily before release	Product security, reputation	Security audits, pen tests	Tech and software firms
Red hat	Vigilantes against black hats	Cyber justice	Hack black hat infrastructure	Criminal groups
Green hat	Newcomers eager to learn	Learning, curiosity	Simple experimental attacks	Low-risk targets

Extra detail from the slides:

- Gray hat vulnerability findings are "sometimes reported" to the owner.
- Corporate spies are also called industrial spies.
- Red hats use aggressive methods and try to disable malicious networks.
- Green hats often take part in online forums and communities.

Analogy: Think of a town. White hat = police doing safety inspections. Black hat = burglar. Gray hat = neighbor who tests your lock without asking, then tells you. Red hat = vigilante who attacks burglars. Blue hat = inspector hired just before a new building opens. Green hat = apprentice. Script kiddie = kid with a borrowed crowbar. Hacktivist = protester. State-sponsored = foreign spy. Cyber terrorist = saboteur. Corporate spy = rival company's mole.

> **ADDED CONTEXT:** Older CEH versions also list: suicide hackers (attack critical infrastructure and do not fear jail or punishment), hacker teams (skilled groups with their own funding), insiders (trusted employees), criminal syndicates (organized crime groups), and organized hackers (well-funded, hierarchical crews). These names can still appear as distractors (verify for v13).

Real-world use: A researcher (who) finds a bug on an airline site without permission and posts it publicly after the airline ignores her (gray hat behavior). She wanted recognition (why). Result: the bug is fixed, but she may face legal action because she had no authorization.

EXAM FOCUS:

- How it is asked: a one-paragraph profile -> "which class is this?"
- Keywords: "without permission but reports it" -> gray hat; "political cause" -> hacktivist; "uses existing tools without understanding" -> script kiddie; "government-funded" -> state-sponsored; "fear, critical infrastructure, ideology" -> cyber terrorist; "hired by a company to spy on a rival" -> corporate spy; "hired before product release" -> blue hat; "attacks black hats" -> red hat; "new and learning" -> green hat.
- Trap: hacktivist vs cyber terrorist. Hacktivists want attention for a cause (defacement, leaks). Cyber terrorists want fear and damage to critical infrastructure.
- Trap: blue hat vs white hat. Both are authorized. Blue hat is an outside tester hired for a specific pre-release test.
- Trap: script kiddie vs green hat. Script kiddies use tools for thrill without wanting to learn. Green hats want to learn.

Memory trick: Colors by light: White = right, Black = attack, Gray = in-between, Blue = before the debut (release), Red = revenge on black hats, Green = new grass (newbie).

3.9 Scope and Limitations of Ethical Hacking

What it is:

Scope (what ethical hacking can do), from the slide:

- It is a crucial component of risk assessment, auditing, counter fraud, and information systems security best practices.
- It is used to identify risks and highlight remedial (fixing) actions.
- It reduces ICT costs by resolving vulnerabilities.

Limitations (what it cannot do), from the slide:

- Unless the business already knows what it is looking for and why it is hiring an outside vendor to hack its systems, there may not be much to gain from the experience.
- An ethical hacker can only help the organization better understand its security system. It is up to the organization to place the right safeguards on the network.

Analogy: A doctor's check-up. It finds problems and recommends treatment (scope). It cannot make you take the medicine (limitation). And if you do not say what is hurting, the check-up may miss it.

> **ADDED CONTEXT:** Ethical hacking is the authorized use of hacking tools and techniques to find vulnerabilities so they can be fixed before attackers exploit them. Why organizations need it: to prevent attackers from gaining access, to find vulnerabilities and assess risk, to analyze and strengthen security posture (policies, controls, network protection), to protect customer data, and to raise security awareness.
>
> **ADDED CONTEXT:** Ethical hacker skills (the summary slide says "skills" were covered). Technical: in-depth knowledge of major operating systems (Windows, Linux, Unix, macOS), networking concepts and hardware, security issues, and ability to launch sophisticated attacks. Non-technical: learns new technologies quickly, strong work ethic, problem solving and communication, follows security policies, and knows local laws and standards.

How it works (ADDED CONTEXT, typical engagement flow):

1. Agree on scope and get written authorization (rules of engagement, NDA).
2. Perform the test within scope.
3. Report findings with risk levels and fixes.
4. The organization fixes the issues; the tester may retest.

Real-world use: A retailer (who) hires a pen test firm before a PCI DSS audit (why). The testers find an exposed admin panel and report it. Result: the retailer fixes it; but a second issue in the report is ignored by management, showing the limitation that the organization must act.

EXAM FOCUS:

- How it is asked: "Which is a limitation of ethical hacking?"
- Keyword for a limitation: "organization must implement safeguards", "must know what it is looking for".
- Trap: "ethical hacking guarantees the network is secure" is always wrong.
- The first thing an ethical hacker must have before starting is written permission (signed authorization). This is a classic best-answer question.

Memory trick: Scope = "RAC-B": Risk assessment, Auditing, Counter fraud, Best practices. Limitation = "I find it, you fix it."

3.10 How AI-Driven Ethical Hacking Helps Ethical Hackers

What it is: AI-driven ethical hacking uses artificial intelligence (AI: software that learns patterns and makes decisions) to make security work more efficient, more effective, and wider in scope. It gives ethical hackers powerful tools against increasingly sophisticated threats.

The ten benefits from the slide:

No.	Benefit	Simple meaning
1	Automation of repetitive tasks	AI runs boring steps like scans and log reading
2	Predictive analysis	AI forecasts likely attacks from past data
3	Advanced threat detection	AI spots unknown or subtle threats
4	Enhanced decision making	AI ranks findings so humans choose faster
5	Adaptive learning	AI improves as it sees new data
6	Enhanced reporting	AI drafts clear reports and summaries
7	Simulation and testing	AI simulates attacks to test defenses
8	Scalability	AI handles large networks and data volumes
9	Continuous monitoring	AI watches systems 24/7
10	Adaptive defense mechanisms	Defenses change automatically as threats change

Analogy: A tireless junior assistant who reads every log, remembers every past attack, drafts your report, and never sleeps. You still check its work and make the decisions.

How it works:

1. The ethical hacker gives the AI data or a task (logs, scan output, a prompt).
2. The AI processes it with machine learning or natural language processing.
3. The AI returns findings, code, summaries, or predictions.
4. The human verifies and acts.

Real-world use: A pen tester (who) feeds 5,000 lines of scan output to an AI assistant and asks for a ranked list of high-risk services (why: save time). Result: the report draft is ready in minutes; the tester verifies each finding manually.

AI angle: Example prompt for reporting:

```
You are assisting an authorized penetration test. Summarize the
attached Nmap results for a non-technical manager. Group findings
by risk (High, Medium, Low) and suggest one fix per finding.
```

Countermeasures and defense: AI output can be wrong (hallucination: confident but false output). Always verify AI results, never paste confidential client data into public AI tools without permission, and follow the rules of engagement.

EXAM FOCUS:

- How it is asked: "Which benefit of AI-driven ethical hacking lets testers handle very large environments?" -> scalability.
- Keywords: "forecast" -> predictive analysis; "24/7" -> continuous monitoring; "learns from new data" -> adaptive learning; "defenses adjust automatically" -> adaptive defense mechanisms.
- Trap: adaptive learning (the AI model improves) vs adaptive defense mechanisms (the defenses change).

Memory trick: Ten benefits as two hands. Left hand "A-P-A-E-A": Automation, Predictive, Advanced detection, Enhanced decisions, Adaptive learning. Right hand "E-S-S-C-A": Enhanced reporting, Simulation, Scalability, Continuous monitoring, Adaptive defense.

3.11 ChatGPT-Powered AI Tools for Ethical Hackers (and ShellGPT)

What it is: ChatGPT-powered AI tools use the capabilities of OpenAI's ChatGPT model to assist ethical hackers in many parts of their work.

Features from the slide:

1. They configure and collect data from a wide range of sources, including social media, forums, websites, and public databases.
2. They use natural language processing (NLP: AI that understands human language) and machine learning (ML: systems that learn from data) to provide real-time assistance, automate tasks, and enhance security professionals' capabilities.
3. They integrate with threat intelligence databases to give context and extra information about identified threats.

Tools named on the slide:

Tool	Location shown on slide	Simple purpose
ShellGPT	Terminal (sgpt command)	AI in the Linux command line
HackerGPT	chat.hackerai.co	AI chat assistant for hacking tasks

Tool	Location shown on slide	Simple purpose
PentestGPT	github.com	AI guide that walks through pen tests
Bug Hunter GPT	chatgpt.com	Custom GPT for bug bounty hunting
h4ckGPT	chatgpt.com	Custom GPT for hacking questions
Ethical Hacker GPT	chatgpt.com	Custom GPT for ethical hacking help

ShellGPT (from the slide): an AI-powered tool that ethical hackers and cybersecurity professionals can use to perform various tasks. The slide screenshot shows it running on Parrot Security OS:

```
[attacker@parrot]-[~]
$ sudo su
[sudo] password for attacker:
[root@parrot]-[/home/attacker]
# sgpt
Please enter your OpenAI API key:
Hello! It seems like your message didn't come through. How can I
assist you with Linux/Parrot Security 6.0 or any programming and
system administration tasks today?
```

What this shows, line by line:

1. The user "attacker" is on a host named "parrot" (Parrot Security, a security Linux distribution).
2. "sudo su" switches to the root (administrator) user. Sudo asks for the user's own password.
3. The prompt changes from $ to #, which means root.
4. "sgpt" starts ShellGPT with no prompt text.
5. On first run, ShellGPT asks for an OpenAI API key (a secret token that lets the tool use OpenAI's service).
6. Because no question was typed, the model replies asking how it can help.

Analogy: ShellGPT is like having a senior Linux admin sitting inside your terminal. You ask in English; it answers or writes the command.

How it works:

1. Install ShellGPT (a Python package) and give it an API key.
2. Type sgpt followed by a question in quotes.
3. The tool sends the prompt over HTTPS to the AI model.
4. The answer comes back as text, code, or a shell command you can choose to run.

Real-world use: A junior tester (who) on an authorized engagement forgets the syntax for a ping sweep. She runs sgpt in shell mode and asks for it (why: speed). Result: ShellGPT proposes the command, she reads it, confirms it is in scope, and runs it.

Tools and commands used here: sudo su, sgpt (full details in section 5). HackerGPT, PentestGPT, Bug Hunter GPT, h4ckGPT, Ethical Hacker GPT (section 4).

AI angle: Example prompts per CEH phase (for authorized testing only):

```
Recon:      "List public sources to research the domain example.com
             for an authorized assessment."
Scanning:   "Write an nmap command to find live hosts in
             10.10.10.0/24 without port scanning."
Scripting:  "Write a Python script that reads a list of URLs and
             reports HTTP status codes."
Reporting:  "Turn these findings into an executive summary with
             risk ratings."
```

> **ADDED CONTEXT:** AI is also used by attackers. Malicious LLM tools such as WormGPT and FraudGPT were sold on criminal forums for writing phishing emails and malware without safety filters. Deepfakes (AI-made fake video or voice) are used for CEO-fraud calls. CEH v13 covers these as AI-powered attacks in later modules (Social Engineering, Malware).
>
> **ADDED CONTEXT:** CEH v13 also includes "Hacking AI" (see the framework in 3.12): attacks on AI systems. The OWASP Top 10 for LLM Applications (2025) starts with LLM01 Prompt Injection, LLM02 Sensitive Information Disclosure, LLM03 Supply Chain, and LLM04 Data and Model Poisoning. Model theft and adversarial inputs are other common terms.

Countermeasures and defense:

- Protect the API key (it is like a password). Do not share it or commit it to Git.
- Do not send client secrets or personal data to public AI services without approval.
- Review every AI-generated command before running it, especially as root.
- Defenders: detect AI-generated phishing with email security and user training; verify voice or video requests through a second channel.

EXAM FOCUS:

- How it is asked: "Which AI tool works in the Linux terminal to generate commands?" -> ShellGPT. "What must be configured before ShellGPT works?" -> an OpenAI API key.
- Keywords: "terminal", "command line", "sgpt" -> ShellGPT; "guides through penetration testing steps" -> PentestGPT.
- Trap: ShellGPT does not hack by itself. It generates text, code, or commands from your prompt.
- Trap: WormGPT and FraudGPT are malicious tools, not ethical hacking tools.

Memory trick: "sgpt = Shell GPT = Say it, Get the command, Press enter, Test it."

3.12 CEH Ethical Hacking Framework (the Five Phases)

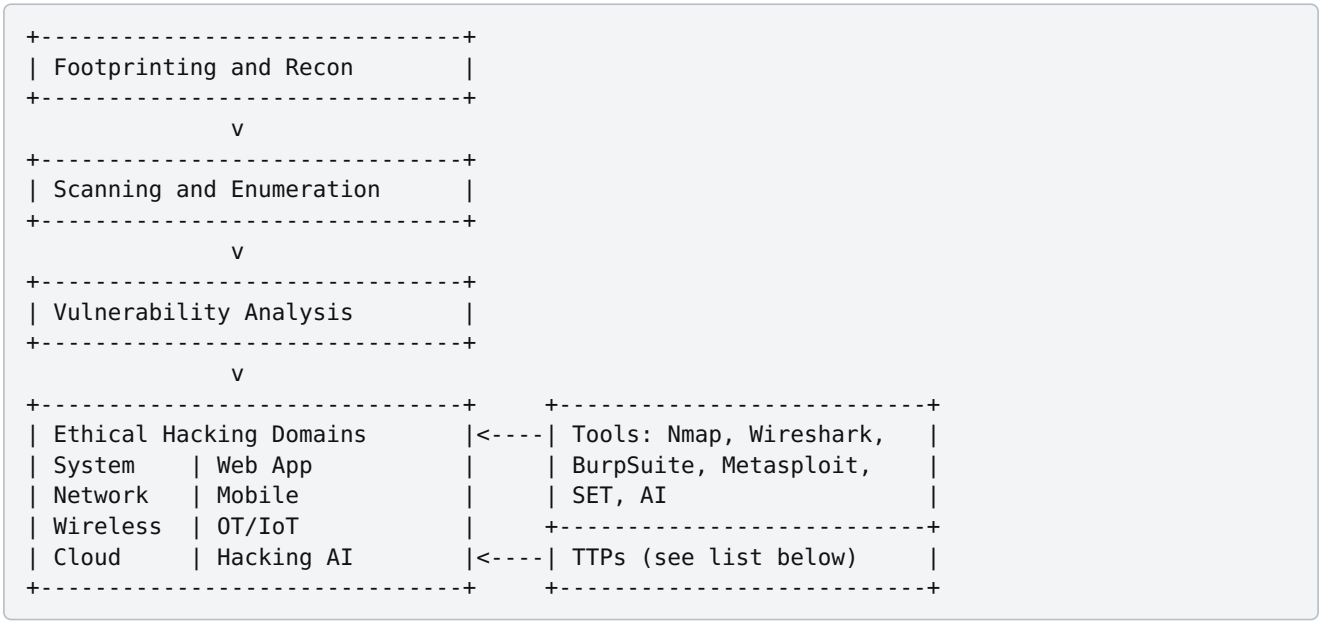
What it is: EC-Council's framework for an ethical hacking engagement. It has five phases, and a flow of activities that feeds into ethical hacking domains, tools, and TTPs.

The five phases (as shown on slide 28):

1. Phase 1: Reconnaissance.
2. Phase 2: Vulnerability Scanning.
3. Phase 3: Gaining Access.
4. Phase 4: Maintaining Access.
5. Phase 5: Clearing Tracks.

> **REMEMBER:** The slide names Phase 2 "Vulnerability Scanning". Most CEH material and exam questions simply call it "Scanning". Treat them as the same phase. This is a small wording conflict between the slide and the common five-phase list.

The flow diagram on the slide:



Ethical hacking domains (8): system hacking, web application hacking, network hacking, mobile hacking, wireless hacking, OT/IoT hacking (OT = operational technology, industrial control systems; IoT = internet of things), cloud hacking, and hacking AI.

Ethical hacking tools on the slide: Nmap (network scanner), Wireshark (packet analyzer), BurpSuite (web proxy for testing web apps), Metasploit (exploitation framework), SET (Social-Engineer Toolkit), and AI.

Ethical hacking TTPs on the slide: password cracking, malware, social engineering, brute forcing, DoS/DDoS, privilege escalation, SQL injection, sniffing, AI, session hijacking, cryptanalysis (breaking or analyzing encryption).

Analogy: A bank robbery movie in five acts: case the bank (recon), check the doors and cameras (scanning), break in (gaining access), hide a key for next time (maintaining access), wipe the fingerprints (clearing tracks). An ethical hacker plays the same five acts with permission, and writes a report instead of stealing.

How it works (ADDED CONTEXT, detail of each phase):

1. Reconnaissance: gather information about the target before attacking. Passive recon uses no direct contact (search engines, WHOIS, social media). Active recon touches the target (calling the help desk, light probing). Covered in Module 02.
2. Scanning: actively probe the target to find live hosts, open ports, services, operating systems, and vulnerabilities. Enumeration (pulling user names, shares, and service details) is grouped here on the slide. Covered in Modules 03 to 05.
3. Gaining access: exploit a weakness to get into the system, for example by password cracking, exploiting a vulnerable service, or social engineering. Includes privilege escalation (getting higher rights). Covered in Module 06 and the domain modules.
4. Maintaining access: keep control for later by installing backdoors, rootkits (hidden malware that hides itself), or Trojans, or by creating new accounts.
5. Clearing tracks: hide evidence by deleting or editing logs, hiding files, using steganography (hiding data inside other files), or tunneling traffic.

Real-world use: A pen test team (who) is hired by an insurer (why: annual test). They research staff names on LinkedIn (recon), scan the external range with Nmap (scanning), phish one user with SET (gaining access), keep a reverse shell open for the test window (maintaining access), and record which logs they could have erased, without erasing them (clearing tracks, simulated). Result: a report with every step and fix.

Tools and commands used here: Nmap, Wireshark, Burp Suite, Metasploit, SET, AI tools (section 4). Short command previews in section 5.

AI angle: AI can help in every phase: summarize OSINT (recon), explain scan output (scanning), suggest exploit modules (gaining access), and draft the report. Example prompt:

```
For an authorized test, explain what each open port in this Nmap
output means and which CEH phase I should do next.
```

Countermeasures and defense:

- Recon: limit public information, staff awareness.
- Scanning: firewalls, IDS/IPS, close unused ports.
- Gaining access: patching, strong passwords, MFA.
- Maintaining access: endpoint detection, integrity monitoring, account reviews.
- Clearing tracks: central log server (SIEM), write-once logs, file integrity monitoring.

EXAM FOCUS:

- How it is asked: "An attacker deletes event logs. Which phase?" -> clearing tracks. "Installs a backdoor?" -> maintaining access. "Uses WHOIS?" -> reconnaissance. "Runs a port scan?" -> scanning.
- Trap: privilege escalation belongs to gaining access, not maintaining access.
- Trap: reconnaissance is the most time-consuming phase in many CEH questions and often the first.
- Look-alike: enumeration vs scanning. Scanning finds open doors; enumeration asks the service for details (user names, shares).

Memory trick: "Real Smart Guys Make Coffee": Reconnaissance, Scanning, Gaining access, Maintaining access, Clearing tracks.

3.13 Cyber Kill Chain Methodology

What it is: The Cyber Kill Chain is part of intelligence-driven defense. It helps identify and prevent malicious intrusion activities. It gives insight into attack phases, so defenders understand the adversary's tactics, techniques, and procedures beforehand.

> **ADDED CONTEXT:** The Cyber Kill Chain was published by Lockheed Martin in 2011. "Kill chain" is a military term: breaking any link stops the attack.

The seven steps (from the slide):

Step	Name	What the attacker does
1	Reconnaissance	Gathers data on the target to probe for weak points
2	Weaponization	Creates a malicious payload using an exploit and a backdoor
3	Delivery	Sends the weaponized bundle by email, USB, and so on
4	Exploitation	Exploits a vulnerability by executing code on the victim
5	Installation	Installs malware on the target system
6	Command and Control	Creates a channel to send data back and forth
7	Actions on Objectives	Performs actions to achieve the intended goals

```
Recon -> Weaponize -> Deliver -> Exploit -> Install -> C2 -> Actions
 (1)       (2)         (3)        (4)        (5)     (6)     (7)
```

Key terms:

- Payload: the malicious code that does the harmful work.
- Exploit: code that takes advantage of a vulnerability.
- Command and control (C2): the attacker's remote channel to the infected machine.

Analogy: A delivery of a poisoned cake. Study the victim (recon), bake the cake (weaponize), post it (deliver), the victim eats it (exploit), the poison settles in (install), the attacker phones to give orders (C2), the attacker gets what they want (actions).

How it works:

1. Attackers move through the steps in order.
2. Defenders map controls to each step.
3. Breaking any one step stops the chain. The earlier you break it, the cheaper the defense.

Real-world use: A SOC (who) notices a phishing email with a macro document (delivery stage) and blocks attachments of that type (why: stop the chain early). Result: the weaponized payload never runs, so there is no exploitation, installation, or C2.

Countermeasures and defense (ADDED CONTEXT, by step):

1. Recon: reduce public exposure, monitor for scanning.
2. Weaponization: threat intelligence on new exploit kits (you cannot see this step directly; it happens on the attacker's side).
3. Delivery: email filtering, USB control, web proxy.
4. Exploitation: patching, exploit protection, application allowlisting.
5. Installation: endpoint protection, least privilege.
6. C2: egress filtering, DNS monitoring, IDS for beaconing traffic.
7. Actions: data loss prevention (DLP), segmentation, backups.

EXAM FOCUS:

- How it is asked: "The attacker creates a malicious PDF with an exploit and backdoor. Which phase?" -> weaponization. "Sends it by email?" -> delivery. "Malware beacons to a remote server?" -> command and control.
- Trap: weaponization vs exploitation. Building the payload = weaponization. Running code on the victim = exploitation.
- Trap: delivery vs installation. Sending = delivery. Putting malware on disk = installation.
- Keywords: "beacon", "callback", "remote channel" -> C2. "Exfiltrate", "encrypt files", "goal" -> actions on objectives.

Memory trick: "Real Women Don't Eat Insects, Chocolate Always": Reconnaissance, Weaponization, Delivery, Exploitation, Installation, Command and control, Actions on objectives.

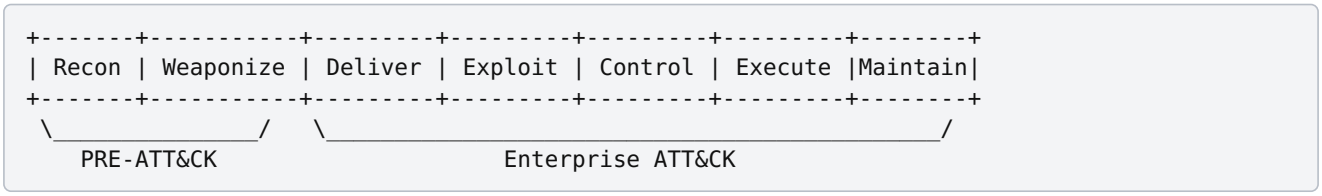
3.14 MITRE ATT&CK Framework

What it is: From the slide:

1. MITRE ATT&CK is a globally accessible knowledge base of adversary tactics and techniques based on real-world observations.
2. It is used as a foundation for specific threat models and methodologies in the private sector, government, and the cybersecurity product and service community.
3. The 14 tactic categories within ATT&CK for Enterprise are derived from the later stages (exploit, control, maintain, and execute) of the seven stages of the Cyber Kill Chain.

ATT&CK stands for Adversarial Tactics, Techniques, and Common Knowledge. Website: https://attack.mitre.org.

The slide arrow:



- PRE-ATT&CK covers Recon and Weaponize (what happens before the attacker touches the target).
- Enterprise ATT&CK covers Deliver, Exploit, Control, Execute, Maintain.

> **ADDED CONTEXT:** The 14 Enterprise tactics: Reconnaissance, Resource Development, Initial Access, Execution, Persistence, Privilege Escalation, Defense Evasion, Credential Access, Discovery, Lateral Movement, Collection, Command and Control, Exfiltration, Impact. In 2020 MITRE merged PRE-ATT&CK into Enterprise as the Reconnaissance and Resource Development tactics. The slide still shows the older split; use the slide wording for the exam.

Each technique has an ID such as T1566 (Phishing) and may have sub-techniques such as T1566.001 (Spearphishing Attachment) (verify IDs on attack.mitre.org).

Analogy: ATT&CK is an encyclopedia of attacker moves, like a chess opening book. Columns are goals (tactics), entries are moves (techniques).

How it works:

1. Analysts observe a real attack.
2. They map each attacker action to a tactic and technique ID.
3. Defenders check which techniques they can detect and close the gaps.
4. Red teams use the same map to emulate real threat groups.

Real-world use: A bank (who) maps its detection rules to ATT&CK and finds no coverage for Lateral Movement techniques (why: gap analysis). Result: they add monitoring for remote service logins.

AI angle: Example prompt: "Map these incident log entries to MITRE ATT&CK tactics and technique IDs and list detection ideas for each." Always check the IDs against the official site.

EXAM FOCUS:

- How it is asked: "Which framework is a knowledge base of adversary tactics and techniques based on real-world observations?" -> MITRE ATT&CK.
- Keywords: "knowledge base", "real-world observations", "tactics and techniques matrix" -> ATT&CK. "Seven sequential stages" -> Cyber Kill Chain.
- Number: 14 tactics in Enterprise ATT&CK.
- Trap: ATT&CK is a matrix (not strictly ordered), the Kill Chain is a linear sequence.

Memory trick: "ATT&CK has 14 columns, like 14 days in two weeks of attack."

3.15 Diamond Model of Intrusion Analysis

What it is: From the slide:

- The Diamond Model is a framework for identifying clusters of events that are correlated on any of the systems in an organization.
- It can control the vital atomic element in any intrusion activity, called the Diamond event.
- With it, efficient mitigation approaches can be developed and analytic efficiency increased.

The four core features:

Feature	Question it answers	Meaning
Adversary	Who	The opponent behind the attack
Victim	Where	The target that was exploited
Capability	How	The attack strategies, tools, and malware
Infrastructure	What	What the adversary used to reach the victim

The relationships drawn on the slide:



Read it as sentences: the adversary uses infrastructure and develops capability; the capability is deployed via infrastructure; the infrastructure connects to the victim; the capability exploits the victim.

> **ADDED CONTEXT:** The slide titles this diagram "Meta Features of Diamond Model". In the original model (Caltagirone, Pendergast, Betz, 2013) the meta-features are Timestamp, Phase, Result, Direction, Methodology, and Resources. The extended model adds two axes: social-political (adversary-victim relationship) and technology (capability-infrastructure). Exam questions may use either view (verify).

Analogy: A crime board in a detective show: the suspect (adversary), the weapon (capability), the getaway car (infrastructure), and the victim. Find any one corner and you can pivot to the others.

How it works:

1. Start from one known feature, for example a malicious IP (infrastructure).
2. Pivot: which malware used it (capability)? Which other victims? Which group (adversary)?
3. Group related diamond events into activity threads and clusters.
4. Build mitigations targeting the shared features.

Real-world use: A threat analyst (who) sees a C2 domain in a firewall log and pivots to find two more victims in the same sector (why: scope the campaign). Result: the whole campaign is blocked at the infrastructure level.

EXAM FOCUS:

- How it is asked: "In the Diamond Model, which feature describes how the attack was performed?" -> capability. "What the adversary used to reach the victim?" -> infrastructure.
- Keywords: "who" -> adversary, "where" -> victim, "how" -> capability, "what" -> infrastructure.
- Trap: infrastructure ("what") and capability ("how") are the two that get swapped.
- Atomic element = the Diamond event.

Memory trick: "A-C-V-I: Always Catch Villains Immediately": Adversary (who), Capability (how), Victim (where), Infrastructure (what). Or "Who uses What to do How to Where".

3.16 Information Assurance (IA)

What it is: Information assurance is the assurance that the integrity, availability, confidentiality, and authenticity of information and information systems are protected during usage, processing, storage, and transmission of information.

Processes that help achieve IA (from the slide):

1. Developing local policy, process, and guidance.
2. Designing network and user authentication strategies.
3. Identifying network vulnerabilities and threats.
4. Identifying problem and resource requirements.
5. Creating plans for identified resource requirements.
6. Applying appropriate information assurance controls.
7. Performing certification and accreditation.
8. Providing information assurance training.

Key terms:

- Certification: a technical evaluation that a system meets its security requirements.
- Accreditation: formal management approval to operate the system after certification.

Analogy: IA is the quality guarantee on a car: it covers the car while driving (usage), in the garage (storage), and being shipped (transmission).

How it works: Plan (policy, strategies) -> find weaknesses -> plan resources -> apply controls -> certify and accredit -> train people. The list moves from planning to doing to checking to people.

> **ADDED CONTEXT:** Information security controls come in three categories. Administrative (policies, training, background checks), Physical (locks, guards, CCTV), and Technical or logical (firewalls, encryption, access control lists). By function they are Preventive (stop), Detective (find), and Corrective (fix). Some lists add deterrent, recovery, and compensating controls.
>
> **ADDED CONTEXT:** Defense-in-depth is a strategy of several layers of security, so if one layer fails the next one still protects. Common layers from outside in: Policies, procedures and awareness; Physical; Perimeter; Internal network; Host; Application; Data.

Real-world use: A government agency (who) must certify and accredit a new HR system before go-live (why: policy). Result: the system gets approval only after vulnerabilities found in testing are fixed.

EXAM FOCUS:

- How it is asked: "Which process is part of information assurance?" -> any of the eight, often "performing certification and accreditation".
- Note: the IA slide lists four properties (integrity, availability, confidentiality, authenticity). Non-repudiation is not in the IA slide definition.
- Trap: IA is broader than technical security; it includes policy and training.
- Defense-in-depth keyword: "multiple layers", "if one layer is breached".

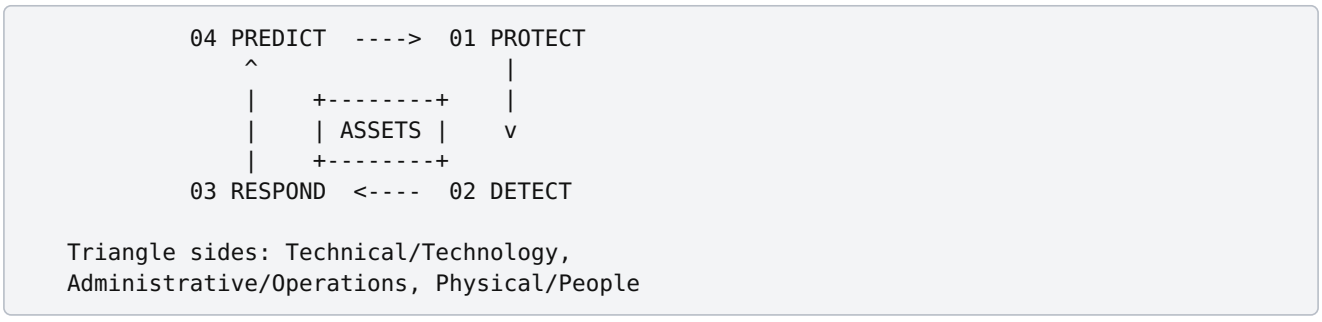
Memory trick: IA 8 processes: "Please Design, Identify, Identify, Create, Apply, Certify, Train" -> "Pretty Dogs In India Can Always Chase Trains".

3.17 Continual/Adaptive Security Strategy

What it is: Organizations should adopt an adaptive security strategy that implements all four network security approaches. Each approach has its own security activities. It is a continuous cycle, not a one-time project.

No.	Approach	Activities from the slide
01	Protect	Defense-in-depth: protect endpoints, network, data
02	Detect	Continuous threat monitoring
03	Respond	Incident response
04	Predict	Risk/vuln assessment, attack surface analysis, threat intel

The slide shows a red cycle around a triangle. The triangle has "Assets" in the center and three sides: Technical (Technology), Administrative (Operations), and Physical (People).



Key terms:

- Endpoint: a user device such as a laptop, phone, or server.
- Attack surface: all the points where an attacker could try to enter.

Analogy: Home safety: lock the doors (protect), install a burglar alarm (detect), call the police when it rings (respond), read neighborhood crime reports to guess what is next (predict).

How it works:

1. Protect: build layered defenses.
2. Detect: monitor continuously for threats that get past.
3. Respond: contain and fix incidents.
4. Predict: learn from incidents and intelligence, then improve protection. The cycle repeats.

Real-world use: An online shop (who) suffers card skimming (respond), studies the attack (predict), adds script integrity checks (protect), and monitors for new script changes (detect). Result: the next attempt is blocked.

EXAM FOCUS:

- How it is asked: "Attack surface analysis belongs to which approach?" -> predict. "Incident response?" -> respond. "Defense-in-depth?" -> protect. "Continuous threat monitoring?" -> detect.
- Trap: threat intelligence is under Predict, not Detect.
- Order on the slide: 01 Protect, 02 Detect, 03 Respond, 04 Predict.

Memory trick: "PDRP: Please Don't Run, Pause": Protect, Detect, Respond, Predict.

3.18 Risk Management

What it is: Risk management is the process of reducing and maintaining risk at an acceptable level by means of a well-defined and actively employed security program.

Risk management phases (from the slide):

Phase	What happens
Risk identification	Finds sources, causes, effects of internal and external risks
Risk assessment	Assesses risk; estimates likelihood and impact
Risk treatment	Selects and implements controls for identified risks
Risk tracking	Ensures controls are in place; calculates chance of new risks
Risk review	Evaluates the performance of the implemented risk strategies

> **ADDED CONTEXT:** Risk treatment options are often listed as: mitigate (reduce with controls), transfer (insurance or outsourcing), avoid (stop the risky activity), and accept (live with it, documented). Residual risk is the risk left after controls.

Analogy: Managing a garden: find the weeds (identify), judge which spread fastest (assess), pull or spray them (treat), check the sprayed areas next week (track), decide if the spray works (review).

How it works: Identify -> Assess -> Treat -> Track -> Review, then repeat.

Real-world use: A hospital (who) identifies ransomware as a top risk, assesses it as high likelihood and severe impact, buys offline backups and EDR (treat), checks monthly that backups run (track), and reviews the program yearly (review). Result: risk reduced to an acceptable level.

EXAM FOCUS:

- How it is asked: order of phases, or "estimating likelihood and impact happens in which phase?" -> risk assessment.
- Trap: tracking (are controls in place, new risks) vs review (did the strategy work).
- Trap: identification finds risks; assessment measures them.

Memory trick: "I Am Taking The Rest": Identification, Assessment, Treatment, Tracking, Review.

3.19 What is Risk? (Risk Levels and Risk Matrix)

What it is: Risk is the degree of uncertainty or expectation that an adverse event may cause damage to the system. Risks are categorized into levels according to their estimated impact. A risk matrix scales risk by probability (likelihood) and consequence (impact).

> **ADDED CONTEXT:** A common CEH formula is Risk = Threat x Vulnerability x Impact (some versions write Asset Value instead of Impact). Level of risk = Consequence x Likelihood (verify exact wording).

Risk levels and actions (from the slide):

Risk level	Action
Extreme or High	Act immediately; impose controls to cut risk to a low level
Medium	No urgent action; implement controls as soon as possible
Low	Take preventive steps to mitigate the effects of risk

Risk matrix (from the slide; rows are likelihood, columns are consequences):

```
Likelihood        Insignif.  Minor   Moderate  Major    Severe
----------------  ---------  ------  --------  -------  -------
81-100 Very High  Low        Medium  High      Extreme  Extreme
61-80  High        Low        Medium  High      High     Extreme
41-60  Equal       Low        Medium  Medium    High     High
21-40  Low         Low        Low     Medium    Medium   High
1-20   Very Low    Low        Low     Medium    Medium   High
```

How to read it: find the likelihood row, then the consequence column. Example: High probability (61-80 percent) with Major consequence -> High risk.

The slide note: this is an example. Each organization must create its own risk matrix based on its business needs.

Analogy: A weather forecast. Chance of rain (likelihood) times how bad the storm is (consequence) tells you whether to cancel the picnic.

Real-world use: A security manager (who) rates "laptop theft" as Equal probability (41-60) with Moderate impact -> Medium (why: prioritize the budget). Result: plan disk encryption soon, but not as an emergency.

EXAM FOCUS:

- How it is asked: read the matrix, or "What action for a medium risk?" -> no urgent action, but implement controls as soon as possible.
- Trap: in this matrix, even Very Low probability with Severe consequence is High risk.
- Trap: "Extreme or High" needs immediate measures.

Memory trick: "High = Hurry, Medium = Make a plan, Low = Look after it."

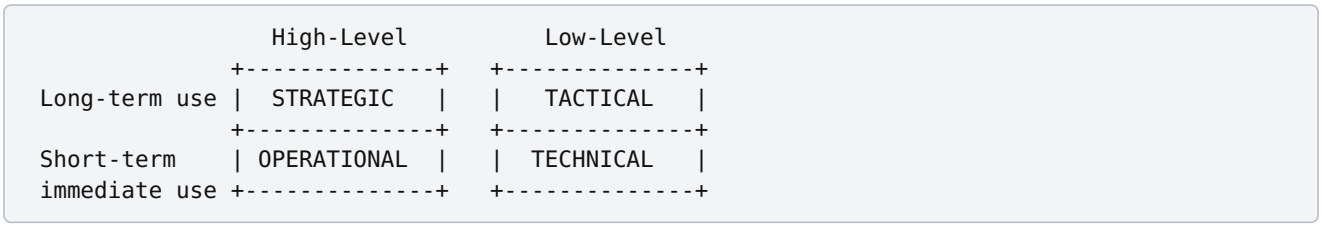
3.20 Cyber Threat Intelligence (CTI)

What it is: CTI is the collection and analysis of information about threats and adversaries, and the drawing of patterns that help make knowledgeable decisions for preparedness, prevention, and response against cyber attacks. It helps an organization identify and mitigate business risks by converting unknown threats into known threats, and supports advanced, proactive defense.

Types of threat intelligence (from the slide):

Type	What it contains	Consumed by	Use and level
Strategic	High-level info on changing risks	Executives and management	Long-term, high-level
Tactical	Attackers' TTPs	IT service and SOC managers, admins	Long-term, low-level
Operational	A specific incoming attack	Security managers, network defenders	Short-term, high-level

Type	What it contains	Consumed by	Use and level
Technical	Specific indicators of compromise	SOC staff and IR teams	Short-term, low-level



Key term: Indicator of compromise (IoC): evidence that a system was attacked, such as a malicious IP, domain, file hash, or registry key.

> **ADDED CONTEXT:** CEH groups IoCs into email indicators (sender address, subject, attachment), network indicators (URLs, domains, IPs), host-based indicators (file names, hashes, registry keys), and behavioral indicators (for example, a PowerShell script running at odd times).

Analogy: A newspaper for defenders. The front-page trend story (strategic), the article on how burglars operate (tactical), the urgent alert "burglars on your street tonight" (operational), and the photo of the burglar's car plate (technical).

How it works: Collect data -> analyze -> deliver the right type to the right audience -> act.

Real-world use: A SOC (who) receives a feed of malicious IPs and hashes (technical) and blocks them in the firewall and EDR (why: immediate defense). The CISO receives a quarterly report on ransomware trends in the sector (strategic). Result: both short-term blocking and long-term budget decisions.

AI angle: AI can parse thousands of threat reports and extract IoCs and TTPs. Example prompt: "Extract all IPs, domains, and file hashes from this threat report and list them as a CSV."

EXAM FOCUS:

- How it is asked: "Board of directors needs a report on risk trends" -> strategic. "List of malicious hashes for the SIEM" -> technical. "TTPs of an APT group" -> tactical. "Details of an attack planned against us next week" -> operational.
- Trap: tactical (TTPs) vs technical (IoCs).
- Trap: operational is about a specific incoming attack, not daily operations in general.

Memory trick: "S-T-O-T": Strategic = Suits (executives), Tactical = TTPs, Operational = Oncoming attack, Technical = Tiny artifacts (IoCs).

3.21 Threat Intelligence Lifecycle

What it is: The continuous five-step process for producing threat intelligence.

1. Planning and Direction: define intelligence requirements; make a collection plan; form an intelligence team; send requests for data collection; plan and set requirements for other phases.
2. Collection: collect required data that satisfies intelligence goals. Sources include OSINT, HUMINT, IMINT, MASINT, and others.
3. Processing and Exploitation: process raw data for exploitation; convert it into a usable format for analysis.
4. Analysis and Production: combine information from phase 3 into a single entity; include facts, findings, and forecasts. Analysis must be objective, timely, accurate, and actionable. Perform confidence-based analysis.
5. Dissemination and Integration: deliver the intelligence to consumers at different levels: strategic (high-level business strategies), tactical (TTPs), operational (specific threats), and technical (IoCs).

Collection source acronyms:

Acronym	Meaning	Example
OSINT	Open-source intelligence	Websites, social media, public records
HUMINT	Human intelligence	Interviews, informants, conversations
IMINT	Imagery intelligence	Satellite or aerial photos
MASINT	Measurement and signature intelligence	Radar, acoustic, or chemical signatures

> **ADDED CONTEXT:** Other INT types: SIGINT (signals intelligence, intercepted communications), GEOINT (geospatial), FININT (financial), TECHINT (technical, about enemy equipment), CYBINT (cyber intelligence), SOCMINT (social media intelligence).

Analogy: Cooking for a dinner party. Plan the menu (planning), shop (collection), wash and chop (processing), cook (analysis and production), serve each guest what they ordered (dissemination).

How it works: The steps run in a loop. Feedback from consumers after step 5 starts a new planning step.

Real-world use: A bank's CTI team (who) is asked "Are we targeted by banking Trojans?" (planning), gathers OSINT and dark web chatter (collection), normalizes the data (processing), writes a report with confidence levels (analysis), and sends IoCs to the

SOC and a summary to executives (dissemination). Result: specific blocks plus a budget request.

EXAM FOCUS:

- How it is asked: order of steps, or "converting raw data into a usable format" -> processing and exploitation.
- Trap: analysis and production (making the product) vs dissemination (delivering it).
- Keyword: "define intelligence requirements" -> planning and direction.
- Keyword: "objective, timely, accurate, actionable" -> analysis and production.

Memory trick: "People Can Process And Deliver" -> Planning, Collection, Processing, Analysis, Dissemination.

3.22 Threat Modeling

What it is: Threat modeling is a risk assessment approach for analyzing the security of an application by capturing, organizing, and analyzing all the information that affects its security.

Threat modeling process (from the slide):

Step	Name	What it does
1	Identify security objectives	Decides how much effort to put into later steps
2	Application overview	Identifies components, data flows, and trust boundaries
3	Decompose the application	Helps find more relevant and detailed threats
4	Identify threats	Finds threats for the control scenario using steps 2 and 3
5	Identify vulnerabilities	Finds weaknesses linked to threats using vuln categories

Key terms:

- Data flow: how data moves between parts of the application.
- Trust boundary: a line where data passes between areas with different trust levels (for example, internet to web server).
- Decompose: break into smaller parts to study each one.

> **ADDED CONTEXT:** Popular threat modeling methods: STRIDE (Microsoft: Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, Elevation of privilege), PASTA (Process for Attack Simulation and Threat Analysis, a 7-stage risk-centric method), DREAD (rates threats by Damage, Reproducibility, Exploitability, Affected users, Discoverability), and OCTAVE.

Analogy: Planning security for a new house before you build it: what to protect (objectives), the floor plan (overview), each room (decompose), how a burglar could enter (threats), which windows are weak (vulnerabilities).

How it works: Steps 1 to 5 in order, best done during design so fixes are cheap.

Real-world use: A fintech developer team (who) threat models a new payment API (why: design review). They find that an internal service trusts any request without checking a token at a trust boundary. Result: authentication is added before code is written.

AI angle: Example prompt: "Using STRIDE, list likely threats for a login API that accepts username and password over HTTPS and stores sessions in Redis."

EXAM FOCUS:

- How it is asked: "Identifying components, data flows, and trust boundaries is which step?" -> application overview. "Which step decides how much effort is needed?" -> identify security objectives.
- Trap: identify threats (step 4) comes before identify vulnerabilities (step 5).

Memory trick: "Our Old Dog Takes Vitamins": Objectives, Overview, Decompose, Threats, Vulnerabilities.

3.23 Incident Handling and Response (IH&R)

What it is: IH&R is the process of taking organized and careful steps when reacting to a security incident or cyberattack. An incident is any event that harms or threatens the security of systems or data.

The nine IH&R steps (from the slide):

1. Preparation.
2. Incident recording and assignment.
3. Incident triage.
4. Notification.
5. Containment.
6. Evidence gathering and forensic analysis.
7. Eradication.
8. Recovery.
9. Post-incident activities: incident documentation, incident impact assessment, review and revise policies, close the investigation, incident disclosure.

Key terms:

- Triage: sort incidents by severity and decide priority (like a hospital emergency room).

- Containment: stop the incident from spreading (for example, isolate an infected host).
- Forensic analysis: collect and examine evidence in a legally sound way.
- Eradication: remove the root cause (malware, attacker accounts).
- Recovery: restore systems to normal operation safely.

Analogy: A house fire. Have extinguishers ready (preparation), log the call (recording), judge how big it is (triage), call the fire brigade and family (notification), close doors to stop spread (containment), find the cause (forensics), put the fire out fully (eradication), rebuild (recovery), write a report and buy better alarms (post-incident).

> **ADDED CONTEXT:** NIST SP 800-61 uses four phases: Preparation; Detection and Analysis; Containment, Eradication, and Recovery; Post-Incident Activity. The CEH nine-step list is a more detailed version of the same idea.

Real-world use: A company's SOC (who) sees ransomware on one laptop. They log a ticket and assign an analyst, rate it critical, notify management, unplug the laptop from the network, image its disk, remove the malware, restore files from backup, and write a lessons-learned report. Result: only one laptop was affected.

EXAM FOCUS:

- How it is asked: order questions; "What is the FIRST action after triage and notification?" -> containment. "Isolating an infected machine?" -> containment.
- Trap: containment comes before eradication. Do not wipe the machine before collecting evidence.
- Trap: evidence gathering (step 6) comes before eradication (step 7), so evidence is not destroyed.
- Incident disclosure is part of post-incident activities.

Memory trick: "Please Record This Note: Contain, Evidence, Erase, Recover, Post": or "PRT-N-CEERP".

3.24 Role of AI and ML in Cyber Security

What it is: Machine learning (ML) and artificial intelligence (AI) are now widely used because computing power, data collection, and storage capabilities have increased.

From the slide:

- ML is used as an unsupervised self-learning system that defines what the normal network looks like (its devices and behavior), then backtracks and reports any deviations or anomalies in real time.
- AI and ML help identify new exploits and weaknesses, which can then be analyzed to mitigate further attacks.

ML classification techniques:

Type	Training data	Sub-techniques	Simple example
Supervised learning	Labeled data	Classification, Regression	Spam or not spam
Unsupervised learning	Unlabeled data	Clustering, Dimensionality reduction	Group similar traffic

- Supervised learning: algorithms receive a set of labeled training data and learn the differences between the labels.
- Unsupervised learning: algorithms receive unlabeled training data and deduce all categories by themselves.
- Classification: predicts a category (malicious or benign).
- Regression: predicts a number (for example, expected attack volume).
- Clustering: groups similar items without labels.
- Dimensionality reduction: reduces many features to the most important few, to simplify analysis.

```
                Machine Learning
               /                \
  Unsupervised Learning     Supervised Learning
    - Dimensionality          - Classification
      Reduction               - Regression
    - Clustering
```

> **ADDED CONTEXT:** A third type, reinforcement learning, learns by trial and reward. It is not on this slide.

Analogy: Supervised = a teacher shows flashcards with answers. Unsupervised = you sort a box of mixed buttons by color and size with no instructions.

How it works (anomaly detection):

1. The system watches normal traffic and builds a baseline.
2. New activity is compared with the baseline.
3. Big deviations are flagged as anomalies in real time.

Real-world use: A university (who) uses an ML-based network detection tool that learns normal traffic (why: detect unknown attacks). One night a lab PC sends 20 GB to an unknown IP. Result: the anomaly is flagged and the exfiltration is stopped.

EXAM FOCUS:

- How it is asked: "Which ML type uses labeled data?" -> supervised. "Clustering is part of?" -> unsupervised. "Regression?" -> supervised.
- Trap: classification and regression are supervised; clustering and dimensionality reduction are unsupervised.

- Keyword: "baseline of normal, report deviations" -> unsupervised self-learning anomaly detection.

Memory trick: "Supervised = CR (Classroom with a teacher: Classification, Regression). Unsupervised = DC (Do it yourself and Cluster: Dimensionality reduction, Clustering)."

3.25 How Do AI and ML Prevent Cyber Attacks?

What it is: Ten areas where AI and ML help prevent attacks (from the slide):

No.	Area	How AI helps (simple)
1	Password protection and authentication	Detects unusual logins, supports biometrics
2	Phishing detection and prevention	Spots fake emails and URLs
3	Threat detection	Finds malicious activity in logs and traffic
4	Vulnerability management	Prioritizes which flaws to patch first
5	Behavioral analytics	Learns normal user behavior, flags odd actions
6	Network security	Detects intrusions and odd traffic
7	AI-based antivirus	Detects malware by behavior, not only signatures
8	Fraud detection	Flags unusual transactions
9	Botnet detection	Finds infected hosts beaconing to C2
10	AI to combat AI threats	Detects deepfakes and AI-generated attacks

Key terms:

- Signature: a known pattern of a specific malware. Signature-based antivirus misses new malware; behavior-based (AI) antivirus can catch it.
- Botnet: a network of infected computers controlled by an attacker.
- Behavioral analytics (UEBA: user and entity behavior analytics): learning what is normal for each user or device.

Analogy: A bank teller who knows each customer's habits. When "you" suddenly withdraw all your money in another country at 3 a.m., she calls you.

Real-world use: A card issuer (who) uses ML fraud detection (why: stop fraud in real time). A card used in two countries within 10 minutes is blocked automatically. Result: losses drop and customers get an alert.

EXAM FOCUS:

- How it is asked: "Which AI capability detects a user downloading far more data than usual?" -> behavioral analytics.
- Trap: AI-based antivirus vs traditional antivirus. AI-based detects unknown (zero-day) malware by behavior.

Memory trick: Group the ten by target: people (passwords, phishing, behavior), systems (threats, vulns, antivirus, network), money (fraud), crowds (botnets), and AI itself (AI vs AI).

3.26 Payment Card Industry Data Security Standard (PCI DSS)

What it is: PCI DSS is a proprietary information security standard for organizations that handle cardholder information for major debit, credit, prepaid, e-purse, ATM, and POS (point of sale) cards. It applies to all entities involved in payment card processing: merchants, processors, acquirers, issuers, and service providers, plus all other entities that store, process, or transmit cardholder data.

High-level overview (six goals from the slide):

1. Build and maintain a secure network.
2. Protect cardholder data.
3. Maintain a vulnerability management program.
4. Implement strong access control measures.
5. Regularly monitor and test networks.
6. Maintain an information security policy.

Failure to meet PCI DSS may result in fines or termination of payment card processing privileges. Website: https://www.pcisecuritystandards.org.

> **ADDED CONTEXT:** The six goals contain 12 requirements (PCI DSS v4.0 wording, summarized): 1 network security controls; 2 secure configurations; 3 protect stored account data; 4 strong cryptography over open networks; 5 anti-malware; 6 secure systems and software; 7 restrict access by need to know; 8 identify users and authenticate; 9 restrict physical access; 10 log and monitor access; 11 test security regularly; 12 security policies and programs.
>
> **ADDED CONTEXT:** PCI DSS is run by the PCI Security Standards Council, founded by Visa, Mastercard, American Express, Discover, and JCB. It is an industry standard, not a law. Never store the full magnetic stripe data, CVV2, or PIN after authorization.

Analogy: A club rule book. If you want to accept card payments (join the club), you must follow the rules, or you are fined or thrown out.

Real-world use: An e-commerce site (who) must pass a PCI DSS assessment to keep accepting Visa (why). It segments the card network, encrypts card data, and runs quarterly scans. Result: it passes; the scope is smaller because card data is isolated.

EXAM FOCUS:

- How it is asked: "An online store processing credit cards must comply with?" -> PCI DSS.
- Keywords: "cardholder data", "merchant", "POS", "acquirer" -> PCI DSS.
- Trap: PCI DSS is proprietary (industry), not government law.
- Number: 6 goals (12 requirements).

Memory trick: "Never Protect Very Angry Monkeys Poorly": Network, Protect data, Vulnerability program, Access control, Monitor and test, Policy.

3.27 ISO/IEC Standards

What it is: ISO (International Organization for Standardization) and IEC (International Electrotechnical Commission) publish the 27000 family of information security standards. Website: https://www.iso.org.

Standard	Focus
ISO/IEC 27001:2022	Requirements to establish, run, and improve an ISMS
ISO/IEC 27701:2019	Extends 27001 with privacy management: PII and a PIMS
ISO/IEC 27002:2022	Best practice controls (access control, crypto, personnel)
ISO/IEC 27005:2022	Information security risk management guidance for an ISMS
ISO/IEC 27018:2019	Code of practice for protecting PII in public clouds
ISO/IEC 27032:2023	Internet security; links web, network, and cybersecurity
ISO/IEC 27033-7:2023	Guidelines for network virtualization security
ISO/IEC 27036-3:2023	Securing hardware, software, and services supply chains
ISO/IEC 27040:2024	Data storage security: plan, design, document, implement

Key terms:

- ISMS (Information Security Management System): the policies, processes, and controls an organization uses to manage information security.
- PIMS (Privacy Information Management System): the same idea for privacy.
- PII (Personally Identifiable Information): data that identifies a person (name, ID number, email).

> **ADDED CONTEXT:** ISO/IEC 27001 is the standard an organization gets certified against. 27002 is guidance on the controls (it has 93 controls in four themes in the 2022 version: organizational, people, physical, technological; verify). 27701 was revised in 2025 as a standalone standard (verify); the slide shows the 2019 version.

Analogy: 27001 is the exam you pass to get the certificate. 27002 is the textbook explaining how to meet each requirement. 27005 is the chapter on risk.

Real-world use: A cloud provider (who) gets ISO 27001 certification and follows 27018 for customer PII (why: win enterprise customers). Result: customers accept its security without auditing it themselves.

EXAM FOCUS:

- How it is asked: "Which standard specifies requirements for an ISMS?" -> 27001. "PII in public clouds?" -> 27018. "Privacy extension to 27001?" -> 27701. "Risk management?" -> 27005. "Supply chain?" -> 27036-3.
- Trap: 27001 (requirements, certifiable) vs 27002 (best practice controls, guidance).

Memory trick: "01 = Original requirements, 02 = Do the controls, 05 = Five risks, 18 = 18-year-old privacy in the cloud, 701 = Privacy add-on, 32 = Internet, 33 = Network, 36 = Supply, 40 = Storage."

3.28 Health Insurance Portability and Accountability Act (HIPAA)

What it is: A US law (ADDED CONTEXT: passed in 1996) that protects health information. The slide shows HIPAA's Administrative Simplification Statute and Rules. Website: https://www.hhs.gov.

Rule	What it requires
Electronic Transaction and Code Set Standards	Same transactions, code sets, identifiers for e-business
Privacy Rule	Federal protection of health info; patient rights
Security Rule	Admin, physical, technical safeguards for CIA of ePHI
National Identifier Requirements	Standard national ID numbers on standard transactions
Enforcement Rule	Standards to enforce all Administrative Simplification rules

Key terms:

- Covered entity: health plans, health care clearinghouses, and providers that transmit health data electronically.
- PHI (protected health information) and ePHI (electronic PHI).

> **ADDED CONTEXT:** The national identifier for providers is the NPI (National Provider Identifier). The HITECH Act (2009) strengthened HIPAA enforcement and added breach notification rules.

Analogy: HIPAA is the doctor's oath turned into law for computers: keep patient files private (privacy), lock the file room (security), use the same forms everywhere (transactions and identifiers), and punish rule breakers (enforcement).

Real-world use: A clinic (who) encrypts laptops holding patient records and trains staff (why: Security Rule). Result: a stolen laptop is not a reportable breach because the data was encrypted (verify the safe-harbor detail with HHS guidance).

EXAM FOCUS:

- How it is asked: "Which rule requires administrative, physical, and technical safeguards for ePHI?" -> Security Rule. "Gives patients rights over their health information?" -> Privacy Rule.
- Keywords: "health", "patient", "ePHI", "covered entities" -> HIPAA.
- Trap: Privacy Rule (all PHI, patient rights) vs Security Rule (electronic PHI, safeguards).

Memory trick: "Every Patient Should Not Escape": Electronic transactions, Privacy, Security, National identifiers, Enforcement.

3.29 Sarbanes-Oxley Act (SOX)

What it is: Enacted in 2002, SOX protects investors and the public by increasing the accuracy and reliability of corporate disclosures (public company financial reports). Its key requirements are organized into 11 titles. Website: https://www.sec.gov.

Title	Name
I	Public Company Accounting Oversight Board (PCAOB)
II	Auditor Independence
III	Corporate Responsibility
IV	Enhanced Financial Disclosures
V	Analyst Conflicts of Interest
VI	Commission Resources and Authority
VII	Studies and Reports
VIII	Corporate and Criminal Fraud Accountability
IX	White Collar Crime Penalty Enhancement
X	Corporate Tax Returns
XI	Corporate Fraud Accountability

> **ADDED CONTEXT:** SOX followed the Enron and WorldCom scandals. Section 302 makes the CEO and CFO personally certify financial reports. Section 404 requires management to assess internal controls over financial reporting, which includes IT controls such as access control and change management.

Analogy: SOX is a lie detector for company accounts. Bosses must sign that the numbers are true, and auditors must be independent.

Real-world use: A listed company (who) restricts who can change the accounting database and logs every change (why: SOX 404 internal controls). Result: auditors can verify reports are reliable.

EXAM FOCUS:

- How it is asked: "Which act protects investors by improving the accuracy of corporate disclosures?" -> SOX.
- Keywords: "investors", "public companies", "financial reporting", "2002", "PCAOB" -> SOX.
- Trap: SOX Title I is PCAOB; Title VIII and XI are both about fraud accountability (VIII corporate and criminal, XI corporate).
- Number: 11 titles.

Memory trick: "SOX = Stock Owners eXpect truth." Titles: "P-A-C-E-A-C-S-C-W-C-C" -> "PCAOB, Auditor, Corporate, Enhanced, Analyst, Commission, Studies, Criminal fraud, White collar, Corporate tax, Corporate fraud."

3.30 DMCA and FISMA

The Digital Millennium Copyright Act (DMCA)

What it is: A United States copyright law (ADDED CONTEXT: signed in 1998) that implements two 1996 treaties of the World Intellectual Property Organization (WIPO). It defines legal prohibitions against circumvention (bypassing) of technological protection measures that copyright owners use to protect their works, and against removal or alteration of copyright management information. Website: https://www.copyright.gov.

- Technological protection measure: DRM (digital rights management), such as copy protection on a game or video.
- Copyright management information: the author name, terms, and ID numbers attached to a work.

> **ADDED CONTEXT:** The two WIPO treaties are the WIPO Copyright Treaty (WCT) and the WIPO Performances and Phonograms Treaty (WPPT). The DMCA also creates the "notice and takedown" safe harbor for online service providers.

The Federal Information Security Management Act (FISMA)

What it is: A US law that provides a comprehensive framework for ensuring the effectiveness of information security controls over information resources that support federal operations and assets. Website: https://csrc.nist.gov.

FISMA includes (from the slide):

1. Standards for categorizing information and information systems by mission impact.
2. Standards for minimum security requirements for information and information systems.
3. Guidance for selecting appropriate security controls for information systems.
4. Guidance for assessing security controls and determining their effectiveness.
5. Guidance for security authorization of information systems.

> **ADDED CONTEXT:** FISMA was passed in 2002 and updated in 2014 as the Federal Information Security Modernization Act. NIST supports it with FIPS 199 (categorization), FIPS 200 (minimum requirements), SP 800-53 (controls), SP 800-53A (assessment), and SP 800-37 (Risk Management Framework, authorization).

Analogy: DMCA = "do not pick the lock on a DVD". FISMA = "every federal office must lock its doors in a standard way, and inspectors check."

Real-world use: A software firm (who) sends a DMCA takedown to remove a cracked copy of its app from a file-sharing site (why: circumvention of its license check). A US agency (who) categorizes its new system as "moderate impact" and selects NIST controls (why: FISMA).

EXAM FOCUS:

- Keywords: "copyright", "circumvention", "DRM", "WIPO" -> DMCA. "Federal agencies", "federal information systems", "NIST" -> FISMA.
- Trap: FISMA applies to US federal agencies (and their contractors), not to private companies in general.

Memory trick: "DMCA = Don't Mess with Copyright Again. FISMA = Federal Information Security Must Apply."

3.31 General Data Protection Regulation (GDPR)

What it is: An EU regulation put into effect on May 25, 2018. It is one of the most stringent privacy and security laws globally. It levies harsh fines against those who violate its standards, with penalties reaching tens of millions of euros. Website: https://gdpr.eu.

GDPR data protection principles (from the slide):

Principle	Meaning
Lawfulness, fairness, and transparency	Processing is lawful, fair, transparent to the data subject
Purpose limitation	Use data only for the purposes stated at collection
Data minimization	Collect and process only as much data as necessary
Accuracy	Keep personal data accurate and up to date
Storage limitation	Keep identifying data only as long as needed
Integrity and confidentiality	Keep data secure and confidential (for example, encryption)
Accountability	The controller must prove compliance with all principles

Key terms:

- Data subject: the person the data is about.
- Data controller: the organization that decides why and how data is processed.
- Data processor: an organization that processes data for the controller.

> **ADDED CONTEXT:** Maximum GDPR fines are 20 million euros or 4 percent of global annual turnover, whichever is higher. Breaches must normally be reported to the supervisory authority within 72 hours. GDPR applies to any organization worldwide that processes personal data of people in the EU.

Analogy: Borrowing someone's car with strict rules: only for the trip you asked for (purpose limitation), only the car you need (minimization), return it on time (storage limitation), keep it safe (integrity and confidentiality), and be able to prove you followed the rules (accountability).

Real-world use: A US web shop (who) sells to customers in France (why GDPR applies). It deletes inactive accounts after two years (storage limitation) and collects no birth dates it does not need (data minimization). Result: lower breach impact and compliance.

EXAM FOCUS:

- How it is asked: scenario -> "which GDPR principle is violated?"
- Keywords: "collected more than needed" -> data minimization; "used for a new purpose" -> purpose limitation; "kept forever" -> storage limitation; "must prove compliance" -> accountability.
- Date: May 25, 2018. Number: 7 principles.

Memory trick: "LPDASIA": Lawfulness, Purpose, Data minimization, Accuracy, Storage, Integrity, Accountability -> "Lazy People Don't Always Study In Advance."

3.32 Data Protection Act 2018 (DPA)

What it is: The DPA 2018 sets out the framework for data protection law in the UK. It updates and replaces the Data Protection Act 1998 and came into effect on 25 May 2018. Website: https://www.legislation.gov.uk.

From the slide, the DPA is an act to:

- Make provision for regulating the processing of information relating to individuals.
- Make provision for the Information Commissioner's functions under certain information regulations.
- Make provision for a direct marketing code of practice, and connected purposes.

It protects individuals regarding the processing of personal data by:

1. Requiring personal data to be processed lawfully and fairly, based on the data subject's consent or another specified basis.
2. Conferring rights on the data subject to obtain information about the processing and to require inaccurate personal data to be rectified (corrected).
3. Conferring functions on the Commissioner, giving that office responsibility to monitor and enforce the provisions.

> **ADDED CONTEXT:** The Information Commissioner leads the ICO (Information Commissioner's Office), the UK data protection regulator. After Brexit, the UK uses "UK GDPR" together with the DPA 2018.

Analogy: The DPA is the UK's local version of the GDPR rule book, with the ICO as the referee.

Real-world use: A UK charity (who) receives a request from a donor to correct a wrong address (why: right to rectification). Result: it must correct the record.

EXAM FOCUS:

- Keywords: "UK", "Information Commissioner", "replaces 1998 act" -> DPA 2018.
- Trap: GDPR and DPA 2018 both took effect on 25 May 2018. GDPR is EU-wide; DPA 2018 is UK.

Memory trick: "DPA = Data Protected in Albion (Britain)."

3.33 Cyber Law in Different Countries

What it is: Each country has its own cyber laws. The screenshot shows the second ("Cont'd") page of the table.

Country	Laws or acts	Website
Italy	Penal Code Article 615 ter	cybercrimelaw.net

Country	Laws or acts	Website
Japan	The Trademark Law (Law No. 127 of 1959)	iip.or.jp
Canada	Copyright Act (R.S.C., 1985, c. C-42)	laws-lois.justice.gc.ca
Canada	Trademarks Act (R.S.C., 1985, c. T-13)	laws-lois.justice.gc.ca
Canada	Canadian Criminal Code Section 342.1	laws-lois.justice.gc.ca
Canada	PIPEDA	priv.gc.ca
Singapore	Computer Misuse Act	sso.agc.gov.sg
South Africa	Trademarks Act 194 of 1993	cipc.co.za
South Africa	Copyright Act of 1978	wipo.int
South Korea	Copyright Act (amended to Act No. 19597, Aug 8, 2023)	wipo.int
South Korea	Industrial Design Protection Act	kipo.go.kr
Belgium	Copyright Law, 30/06/1994	wipo.int
Belgium	Computer Hacking	cybercrimelaw.net
Brazil	Brazilian General Data Protection Law (LGPD)	iapp.org
Hong Kong	Article 139 of the Basic Law	basiclaw.gov.hk
Philippines	Republic Act No. 10175	lawphil.net

What some of these are (ADDED CONTEXT):

- Italy Article 615 ter: crime of unauthorized access to a computer or telecommunication system.
- Canada Criminal Code 342.1: unauthorized use of a computer.
- PIPEDA: Personal Information Protection and Electronic Documents Act, Canada's private-sector privacy law.
- Singapore Computer Misuse Act: offences for unauthorized access and modification of computer material.
- LGPD: Lei Geral de Protecao de Dados, Brazil's GDPR-like privacy law (Law No. 13,709 of 2018).
- Hong Kong Basic Law Article 139: government policy on science and technology, including protecting scientific achievements, patents, and copyrights (verify).
- Philippines RA 10175: the Cybercrime Prevention Act of 2012.

> **ADDED CONTEXT:** The first page of this table (not in the screenshots) lists other countries. Commonly cited examples: USA (Computer Fraud and Abuse Act, 18 U.S.C. 1030), UK (Computer Misuse Act 1990), Australia (Cybercrime Act 2001), India (Information Technology Act 2000), Germany (Penal Code Section 202a, data espionage). Verify the exact rows against the courseware.

Real-world use: A pen tester (who) based in Canada is hired to test a server in Brazil (why: global client). She checks both PIPEDA and LGPD before handling any personal data found during the test. Result: the contract includes data handling rules for both countries.

EXAM FOCUS:

- How it is asked: "Which country's law is LGPD?" -> Brazil. "PIPEDA?" -> Canada. "Republic Act 10175?" -> Philippines.
- Trap: Singapore and the UK both have a "Computer Misuse Act".
- Exam questions on country tables are rare but possible; focus on PIPEDA, LGPD, CFAA, and Computer Misuse Act.

Memory trick: "Pipe in Canada, Lungs (LGPD) in Brazil, Ten-one-seven-five in the Philippines."

4. Tool Encyclopedia

4.1 Tools named in the screenshots

Tool	What it does (simple)	Type or platform	Phase used	Exam keyword
Nmap	Finds live hosts, open ports, services, OS	Network scanner, CLI, cross-platform	Scanning	"port scan", "service version", "OS detection"
Wireshark	Captures and decodes network packets	Packet analyzer, GUI	Scanning, sniffing	"capture traffic", "analyze packets", "pcap"
Burp Suite	Intercepts and changes web traffic	Web proxy, Java GUI	Gaining access (web)	"intercept HTTP", "web proxy", "repeater"
Metasploit	Runs exploits and payloads	Exploitation framework, CLI	Gaining and maintaining access	"exploit module", "payload", "meterpreter"
SET	Builds phishing and social engineering attacks	Social-Engineer Toolkit, Linux CLI	Gaining access	"credential harvester", "phishing campaign"
AI	Automates tasks, analysis, reporting	Many tools (see below)	All phases	"automate", "LLM", "prompt"
ShellGPT	AI assistant inside the terminal	Python CLI, needs OpenAI API key	All phases	"sgpt", "terminal AI", "generate command"
HackerGPT	AI chat for hacking questions	Web chat (chat.hackerai.co)	All phases	"AI chatbot for hackers"
PentestGPT	AI that guides pen test steps	Open source on GitHub	All phases	"guides penetration testing"
Bug Hunter GPT	Custom GPT for bug bounty work	ChatGPT custom GPT	Recon, vuln analysis	"bug bounty AI"
h4ckGPT	Custom GPT for hacking help	ChatGPT custom GPT	All phases	"hacking assistant GPT"
Ethical Hacker GPT	Custom GPT for ethical hacking help	ChatGPT custom GPT	All phases	"ethical hacking GPT"
Parrot Security OS	Security-focused Linux distribution	Operating system	All phases	"pen testing distro"

4.2 Close alternatives the exam often places next to them

Tool	What it does (simple)	Type or platform	Phase used	Exam keyword
Kali Linux	Security Linux distro with hundreds of tools	Operating system	All phases	"pen testing distro"
hping3	Crafts custom TCP/IP packets	Packet crafter, CLI	Scanning	"craft packets", "firewall testing"
Netcat (nc)	Reads and writes raw network connections	CLI "Swiss army knife"	Scanning, access	"banner grab", "reverse shell"
tcpdump	Captures packets on the command line	CLI sniffer	Sniffing	"CLI packet capture"
OWASP ZAP	Free web app scanner and proxy	Web proxy, GUI	Web testing	"open source Burp alternative"
Nessus	Finds known vulnerabilities	Vulnerability scanner	Vulnerability analysis	"vulnerability scan report"
OpenVAS	Open source vulnerability scanner	Vulnerability scanner	Vulnerability analysis	"free Nessus alternative"
Maltego	Maps relationships from OSINT	Recon GUI	Reconnaissance	"link analysis", "OSINT graph"
theHarvester	Collects emails and subdomains	Recon CLI	Reconnaissance	"harvest emails"
John the Ripper	Cracks password hashes	Password cracker	Gaining access	"crack hashes"
Hashcat	GPU password hash cracker	Password cracker	Gaining access	"GPU cracking"
sqlmap	Automates SQL injection	Web attack CLI	Gaining access	"automated SQLi"
Gophish	Runs phishing simulations	Phishing framework	Gaining access, awareness	"phishing campaign"
WormGPT	Malicious LLM without safety filters	Criminal AI tool	Attacker use	"AI-written malware or BEC"
FraudGPT	Malicious LLM sold for fraud	Criminal AI tool	Attacker use	"AI phishing kits"
MITRE ATT&CK Navigator	Visual map of ATT&CK coverage	Web app	Defense planning	"map detections to ATT&CK"

TRAP: Wireshark captures and analyzes packets; it does not scan ports. Nmap scans ports; it does not decode full packet captures. Burp Suite is for web traffic only.

EXAM TIP: "Which tool is best for social engineering attacks such as credential harvesting?" -> SET. "Which framework provides exploits and payloads?" -> Metasploit.

5. Command Sheet

The screenshots contain two commands: sudo su and sgpt (ShellGPT). They are explained fully below. Section 5.3 adds short previews of the tools named in the framework, so their commands look familiar later.

5.1 sudo su

Purpose: Switch from a normal user to the root (administrator) user on Linux.

Full syntax:

```
sudo su [-] [username]
```

Breakdown:

- sudo: "superuser do". Runs the next command with root rights, after asking for your own password.
- su: "substitute user". Starts a shell as another user. With no user name it means root.
- The optional "-" (or -l) starts a full login shell with the target user's environment.

Flag	Meaning	When to use	Example
(none)	Become root, keep current directory	Quick admin work	sudo su
-	Login shell, load root's environment	Clean root environment	sudo su -
username	Switch to that user	Act as a service account	sudo su postgres
sudo -i	Alternative: root login shell	Same goal as sudo su -	sudo -i

Demo commands (authorized lab on Parrot OS):

```
# Become root before installing a tool
sudo su
# Become root with root's environment
sudo su -
```

Sample output:

```
[attacker@parrot]-[~]
$ sudo su
[sudo] password for attacker:
[root@parrot]-[/home/attacker]
#
```

How to read it:

1. "$" means a normal user.
2. Sudo asks for the user's own password (attacker), not root's password.
3. The prompt changes to root@parrot and "#". You are now root.
4. The directory stays /home/attacker because no "-" was used.

Common mistakes: Typing root's password instead of your own; staying root longer than needed; running untrusted AI-generated commands as root.

What the exam asks: The "#" prompt means root; "$" means a normal user. Running tools such as Nmap SYN scans needs root rights.

5.2 sgpt (ShellGPT)

Purpose: Ask an AI model questions, generate shell commands, generate code, or chat, directly from the terminal.

Full syntax:

```
sgpt [OPTIONS] "PROMPT"
```

Breakdown:

- sgpt: the ShellGPT program.
- OPTIONS: flags that change the mode (shell, code, chat).
- "PROMPT": your question in quotes. Input can also be piped in with "|" or "<".

Setup (first run): ShellGPT asks for an OpenAI API key and stores it in ~/.config/shell_gpt/.sgptrc (OPENAI_API_KEY). It can also read the key from the OPENAI_API_KEY environment variable. Install with pip install shell-gpt (verify package name for your distribution).

Flag	Meaning	When to use	Example
-s, --shell	Generate a shell command, then offer Execute, Describe, Abort	Forgot a command	sgpt -s "list open ports"
-d, --describe-shell	Explain what a command does	Understand a command	sgpt -d "nmap -sS -p- host"
-c, --code	Output only code, no prose	Write a script	sgpt -c "python port checker"
--chat ID	Continue a named conversation	Multi-step tasks	sgpt --chat recon "..."
--repl ID	Interactive chat loop	Long sessions	sgpt --repl temp
--list-chats, -lc	List saved chat sessions	Find old work	sgpt -lc

Flag	Meaning	When to use	Example
--show-chat ID	Show messages of a chat	Review a session	sgpt --show-chat recon
--model TEXT	Pick the AI model	Use another model	sgpt --model gpt-4o "..."
--temperature N	Randomness 0.0 to 2.0 (default 0.0)	More creative output	sgpt --temperature 0.7 "..."
--top-p N	Limit probable tokens 0.0 to 1.0	Fine-tune output	sgpt --top-p 0.5 "..."
--role NAME	Use a saved system role	Persona, for example "pentester"	sgpt --role auditor "..."
--create-role NAME	Create a new role	Reusable instructions	sgpt --create-role auditor
--no-interaction	Shell mode without the E/D/A prompt	Scripts	sgpt -s --no-interaction "..."
--md, --no-md	Turn markdown output on or off	Plain text output	sgpt --no-md "..."
--no-cache	Do not reuse a cached answer	Fresh answer	sgpt --no-cache "..."
--editor	Write the prompt in $EDITOR	Long prompts	sgpt --editor

(Flags checked against the ShellGPT README on GitHub, TheR1D/shell_gpt; the default model name changes over time, so verify.)

Demo commands (authorized lab only):

```
# 1. Generate a ping sweep command for the lab subnet
sgpt -s "nmap command to find live hosts in 10.10.10.0/24"

# 2. Explain a command before running it
sgpt -d "nmap -sS -sV -p 1-1000 10.10.10.5"

# 3. Summarize a scan result for the report
cat scan.txt | sgpt "summarize open ports and risks for a manager"
```

Sample output (demo 1):

```
nmap -sn 10.10.10.0/24
[E]xecute, [D]escribe, [A]bort: d
This command performs a ping scan (-sn) on all 256 addresses in
10.10.10.0/24 to find live hosts without scanning ports.
[E]xecute, [D]escribe, [A]bort: e
Nmap scan report for 10.10.10.1
Host is up (0.0011s latency).
Nmap scan report for 10.10.10.5
Host is up (0.0020s latency).
Nmap done: 256 IP addresses (2 hosts up) scanned in 2.41 seconds
```

How to read it:

1. Line 1 is the command ShellGPT generated.
2. The E/D/A menu lets you Execute, Describe, or Abort. Always describe first if unsure.
3. The description explains -sn (host discovery only).
4. After "e", the real Nmap output appears: two hosts are up.

Common mistakes:

- Running a generated command without reading it (it may be wrong or out of scope).
- Forgetting quotes around the prompt, so the shell splits the words.
- Leaking the API key in screenshots, scripts, or Git.
- Sending client confidential data to a public AI service without approval.

What the exam asks: what ShellGPT is (AI tool in the terminal), what it needs (OpenAI API key), what -s does (generate shell commands), and that AI output must be verified by the human tester.

5.3 Preview commands for framework tools (ADDED CONTEXT)

> **ADDED CONTEXT:** These tools are only named in Module 01. Their full flag sets are taught in later modules (Nmap in Module 03, Wireshark in Module 08, Metasploit in Module 06, SET in Module 09, Burp Suite in Module 14).

Nmap (network scanner). Purpose: find hosts, ports, services.

```
nmap -sn 10.10.10.0/24          # host discovery only, no ports
sudo nmap -sS -p 1-1000 10.10.10.5   # TCP SYN (half-open) scan
nmap -sV -O 10.10.10.5          # service versions and OS guess
```

Flag	Meaning	When to use	Example
-sn	Ping scan, no port scan	Find live hosts	nmap -sn 10.0.0.0/24
-sS	SYN scan (stealth, half-open), needs root	Default fast scan	nmap -sS host
-sT	Full TCP connect scan	No root rights	nmap -sT host
-sV	Detect service versions	Find vulnerable versions	nmap -sV host
-O	Guess the operating system	OS fingerprinting	nmap -O host
-p	Choose ports (-p- means all 65535)	Limit or widen scope	nmap -p 80,443 host
-A	Aggressive: OS, version, scripts, traceroute	Full detail, noisy	nmap -A host

Sample output:

```
PORT    STATE  SERVICE  VERSION
22/tcp  open   ssh      OpenSSH 8.9p1
80/tcp  open   http     Apache httpd 2.4.52
443/tcp closed https
```

Read it: port 22 runs SSH and is open; port 80 runs Apache 2.4.52 and is open; 443 answered but nothing is listening (closed). "filtered" would mean a firewall blocked the probe.

Wireshark (packet analyzer). Purpose: capture and read packets. Display filters you will see often:

```
ip.addr == 10.10.10.5        show traffic to or from one host
tcp.port == 80               show HTTP port traffic
http.request.method == "POST"   show HTTP POST requests
tcp.flags.syn == 1 && tcp.flags.ack == 0   show SYN packets only
```

Metasploit (exploitation framework). Purpose: select an exploit, set options, run it.

```
msfconsole                     # start the framework
search type:exploit smb        # find modules
use exploit/windows/smb/ms17_010_eternalblue
set RHOSTS 10.10.10.5          # target host
set LHOST 10.10.10.2           # attacker IP for reverse shell
exploit                        # or: run
```

Key words: module (exploit, auxiliary, payload, post), RHOSTS (remote target), LHOST (local listener), Meterpreter (advanced payload shell).

SET (Social-Engineer Toolkit). Purpose: build social engineering attacks such as a credential harvester page.

```
sudo setoolkit
# Menu path: 1) Social-Engineering Attacks
#   -> 2) Website Attack Vectors
#   -> 3) Credential Harvester Attack Method
#   -> 2) Site Cloner
```

Burp Suite (web proxy). Purpose: intercept browser traffic. Set the browser proxy to 127.0.0.1 port 8080 (Burp default), then use Proxy, Repeater, Intruder tabs.

> **EXAM TIP:** In Module 01 the exam only expects you to know what each tool is for and which phase it fits. Flag-level questions come in later modules.

6. Ports, Protocols, Standards and Acronyms

6.1 Ports and protocols linked to this module

Module 01 slides show no port numbers. The ports below are linked to the tools and attacks the slides name (ADDED CONTEXT). They are worth memorizing early.

Protocol	Simple purpose	Default port or layer	Known weakness	Related attack or tool
HTTP	Web pages	TCP 80, Layer 7	Plain text, readable	Sniffing, MITM, Burp Suite
HTTPS (TLS)	Encrypted web	TCP 443, Layer 7	Weak ciphers, fake certs	MITM, ShellGPT API calls use it
DNS	Name to IP lookup	UDP/TCP 53, Layer 7	Spoofing, tunneling	C2 over DNS, recon
SMTP	Sending email	TCP 25, Layer 7	Spoofed senders	Phishing delivery
SSH	Encrypted remote login	TCP 22, Layer 7	Weak passwords	Brute forcing
Telnet	Plain text remote login	TCP 23, Layer 7	No encryption	Sniffing credentials
FTP	File transfer	TCP 20/21, Layer 7	Plain text logins	Sniffing, brute force
SMB	Windows file sharing	TCP 445, Layer 7	Old versions exploitable	EternalBlue, Metasploit
RDP	Windows remote desktop	TCP 3389, Layer 7	Exposed to internet	Brute force, ransomware entry
Burp proxy	Local intercepting proxy	TCP 8080 on 127.0.0.1	Not a protocol; tool default	Burp Suite
Metasploit handler	Default reverse shell listener	TCP 4444	Not a protocol; tool default	Metasploit payloads
ICMP	Ping and error messages	Layer 3 (no ports)	Used for discovery	Nmap -sn, ping sweep
TCP	Reliable connections	Layer 4	Handshake can be abused	SYN scans, SYN floods
UDP	Fast, connectionless	Layer 4	Easy to spoof	Amplification DoS

6.2 Standards, laws and frameworks

Name	Simple purpose	Region or scope	Key detail	Exam keyword
PCI DSS	Protect cardholder data	Global card industry	6 goals, 12 requirements	"credit card", "merchant"
ISO/IEC 27001	ISMS requirements	International	Certifiable	"ISMS"

Name	Simple purpose	Region or scope	Key detail	Exam keyword
ISO/IEC 27002	Security controls guidance	International	Best practices	"control objectives"
HIPAA	Protect health information	USA	5 rules on slide	"patient", "ePHI"
SOX	Accurate financial reports	USA public companies	2002, 11 titles	"investors", "PCAOB"
DMCA	Copyright and anti-circumvention	USA	WIPO 1996 treaties	"DRM", "copyright"
FISMA	Federal system security	USA federal agencies	NIST standards	"federal", "NIST"
GDPR	EU personal data privacy	EU (global reach)	25 May 2018, 7 principles	"EU citizens", "data subject"
DPA 2018	UK data protection	UK	Replaced DPA 1998	"Information Commissioner"
PIPEDA	Private sector privacy	Canada	Personal information	"Canada privacy"
LGPD	Personal data protection	Brazil	GDPR-like	"Brazil privacy"
Cyber Kill Chain	Attack stages model	Lockheed Martin	7 steps, linear	"weaponization"
MITRE ATT&CK	Adversary TTP knowledge base	MITRE	14 Enterprise tactics	"real-world observations"
Diamond Model	Intrusion analysis model	Intelligence analysis	4 core features	"adversary, capability"

6.3 Acronyms

Acronym	Meaning	Where it appears
CIA	Confidentiality, Integrity, Availability	Elements of security
TTP	Tactics, Techniques, Procedures	Attacks, ATT&CK
ICT	Information and Communication Technologies	Information warfare
DoS / DDoS	(Distributed) Denial of Service	Active attacks
MITM	Man-in-the-Middle	Active attacks
SQLi	SQL Injection	Active attacks, web
AI / ML	Artificial Intelligence / Machine Learning	AI sections
NLP	Natural Language Processing	ChatGPT tools
LLM	Large Language Model	AI tools, OWASP LLM Top 10
API	Application Programming Interface	ShellGPT API key

Acronym	Meaning	Where it appears
SET	Social-Engineer Toolkit	Framework tools
OT / IoT	Operational Technology / Internet of Things	Hacking domains
C2	Command and Control	Kill chain
ATT&CK	Adversarial Tactics, Techniques, and Common Knowledge	MITRE
IA	Information Assurance	Security management
CTI	Cyber Threat Intelligence	Threat intelligence
IoC	Indicator of Compromise	Technical intelligence
SOC	Security Operations Center	CTI consumers
IR	Incident Response	CTI consumers, IH&R
IH&R	Incident Handling and Response	Incident process
OSINT	Open-Source Intelligence	TI collection
HUMINT	Human Intelligence	TI collection
IMINT	Imagery Intelligence	TI collection
MASINT	Measurement and Signature Intelligence	TI collection
PCI DSS	Payment Card Industry Data Security Standard	Standards
POS	Point of Sale	PCI DSS
ISMS	Information Security Management System	ISO 27001
PIMS	Privacy Information Management System	ISO 27701
PII	Personally Identifiable Information	ISO 27701, 27018
HIPAA	Health Insurance Portability and Accountability Act	Laws
PHI / ePHI	(Electronic) Protected Health Information	HIPAA
SOX	Sarbanes-Oxley Act	Laws
PCAOB	Public Company Accounting Oversight Board	SOX Title I
DMCA	Digital Millennium Copyright Act	Laws
WIPO	World Intellectual Property Organization	DMCA
FISMA	Federal Information Security Management Act	Laws
NIST	National Institute of Standards and Technology	FISMA

Acronym	Meaning	Where it appears
GDPR	General Data Protection Regulation	Laws
DPA	Data Protection Act 2018	UK law
ICO	Information Commissioner's Office	DPA 2018
PIPEDA	Personal Information Protection and Electronic Documents Act	Canada
LGPD	Lei Geral de Protecao de Dados	Brazil
SIEM	Security Information and Event Management	Defense (added)
EDR	Endpoint Detection and Response	Defense (added)
APT	Advanced Persistent Threat	Attack vectors (added)

6.4 Rare terms worth a short introduction

- MASINT: intelligence from measuring physical signatures (radar, sound, radiation). Used mainly by military and government agencies. Attackers do not use it; it appears on the exam only as a collection source name.
- IMINT: intelligence from images (satellite, drone, photos). For cyber, think of photos of an office that reveal badge designs or screens.
- Diamond event: the single atomic record in the Diamond Model, one adversary using one capability over one infrastructure against one victim.
- Trust boundary: in threat modeling, the place where data crosses from less trusted to more trusted areas. Attackers care because checks are often missing there.
- OT (operational technology): computers that control physical processes (factories, power grids). Attackers care because damage is physical; cyber terrorists target it.

7. Attack vs Countermeasure and Look-alike Comparisons

7.1 Attacks and their countermeasures

Attack	Class	Main countermeasure
Sniffing	Passive	Encryption (TLS, VPN, SSH)
Eavesdropping (network)	Passive	Encryption, secure protocols
DoS / DDoS	Active	Rate limiting, DDoS protection, redundancy
Man-in-the-middle	Active	TLS with certificate checks, mutual authentication
Session hijacking	Active	Secure random session IDs, HTTPS, timeouts
SQL injection	Active	Parameterized queries, input validation
Shoulder surfing	Close-in	Privacy screens, awareness
Dumpster diving	Close-in	Shredding policy, locked bins
Eavesdropping (physical)	Close-in	Private rooms, awareness
Planting keyloggers or backdoors	Insider	Least privilege, monitoring, EDR
Theft of physical devices	Insider	Asset tracking, disk encryption
Tampered hardware or software	Distribution	Trusted suppliers, code signing, hash checks
Phishing (AI-generated)	Social engineering	Email filtering, training, MFA
Deepfake voice or video fraud	AI-powered	Call-back verification, approval workflows
Prompt injection on an LLM	Attack on AI	Input and output filtering, least privilege for AI
Log deletion	Clearing tracks	Central SIEM, write-once log storage

7.2 Look-alike pairs

X vs Y	Difference in one line	How to tell them apart
Passive vs active attack	Watch vs change	"No data altered" means passive
Close-in vs insider	Physically near vs trusted with access	"Employee" or "privileged" means insider
Insider vs distribution	Abuse own access vs tamper before install	"In transit", "factory" means distribution

X vs Y	Difference in one line	How to tell them apart
Integrity vs authenticity	Unchanged vs genuine	"Altered" vs "forged sender"
Authenticity vs non-repudiation	Genuine vs cannot deny	"Cannot deny sending" means non-repudiation
Tactics vs techniques	Overall strategy vs technical method	"Strategy start to end" means tactics
Techniques vs procedures	Method vs exact step sequence	"Systematic approach" means procedures
Gray hat vs white hat	No permission vs authorized	"Without permission" means gray hat
White hat vs blue hat	Ongoing professional vs hired pre-release	"Before product release" means blue hat
Red hat vs white hat	Attacks black hats vs defends own org	"Vigilante, aggressive" means red hat
Hacktivist vs cyber terrorist	Cause and publicity vs fear and damage	"Critical infrastructure, fear" means terrorist
Script kiddie vs green hat	Thrill with tools vs eager to learn	"Wants to learn" means green hat
State-sponsored vs corporate spy	Government vs company employer	"Rival company" means corporate spy
Kill Chain vs ATT&CK	7 linear stages vs matrix of tactics	"Knowledge base, observations" means ATT&CK
ATT&CK vs Diamond Model	TTP catalogue vs analysis of one event	"Adversary, victim, capability" means Diamond
Weaponization vs delivery	Build payload vs send it	"Email, USB" means delivery
Exploitation vs installation	Run code vs install malware	"Persistent malware placed" means installation
Strategic vs tactical CTI	Executives vs TTPs	"Board", "trends" means strategic
Operational vs technical CTI	Specific attack vs IoCs	"Hashes, IPs" means technical
Risk assessment vs identification	Measure vs find	"Likelihood and impact" means assessment
Risk tracking vs review	Controls in place vs strategy performance	"Evaluate performance" means review
Containment vs eradication	Stop spread vs remove cause	"Isolate host" means containment
Supervised vs unsupervised ML	Labeled vs unlabeled data	"Clustering" means unsupervised
Classification vs regression	Category vs number	"Predict a value" means regression
ISO 27001 vs 27002	Requirements vs control guidance	"Certification" means 27001
HIPAA Privacy vs Security Rule	All PHI rights vs ePHI safeguards	"Technical safeguards" means Security Rule

X vs Y	Difference in one line	How to tell them apart
GDPR vs DPA 2018	EU regulation vs UK act	"Information Commissioner" means DPA
Defensive vs offensive InfoWar	Protect own ICT vs attack opponent ICT	"Deterrence" is defensive
AI-driven ethical hacking vs AI-powered attack	Authorized defense vs criminal use	"WormGPT, FraudGPT" means attack

8. Exam Cheat Sheet

8.1 Keyword -> answer

- "cannot deny sending or receiving" -> non-repudiation
- "only authorized can read" -> confidentiality
- "prevent unauthorized changes" -> integrity
- "accessible when needed" -> availability
- "genuine" -> authenticity
- "Motive + Method + Vulnerability" -> attack formula
- "strategy from beginning to end" -> tactics
- "monitoring traffic, no change" -> passive attack
- "tamper with data in transit" -> active attack
- "physical proximity" -> close-in attack
- "privileged access to violate rules" -> insider attack
- "tamper before installation" -> distribution attack
- "use of ICT for competitive advantage" -> information warfare
- "finds vulnerabilities without permission" -> gray hat
- "pre-made scripts, no understanding" -> script kiddie
- "political or social cause" -> hacktivist
- "hired before product release" -> blue hat
- "vigilante against black hats" -> red hat
- "newcomer learning" -> green hat
- "spreading fear, critical infrastructure" -> cyber terrorist
- "AI in the terminal, sgpt" -> ShellGPT
- "deletes logs" -> clearing tracks
- "installs backdoor" -> maintaining access
- "create payload with exploit and backdoor" -> weaponization
- "channel to pass data back and forth" -> command and control
- "knowledge base, real-world observations" -> MITRE ATT&CK
- "who, where, how, what" -> Diamond Model
- "Diamond event" -> atomic element of the Diamond Model
- "certification and accreditation" -> information assurance process
- "attack surface analysis" -> predict (adaptive security)
- "estimate likelihood and impact" -> risk assessment
- "IoCs for SOC" -> technical threat intelligence
- "specific incoming attack" -> operational threat intelligence
- "raw data to usable format" -> processing and exploitation
- "components, data flows, trust boundaries" -> application overview (threat modeling)
- "isolate infected system" -> containment
- "labeled training data" -> supervised learning

- "cardholder data" -> PCI DSS
- "ISMS requirements" -> ISO/IEC 27001
- "PII in public clouds" -> ISO/IEC 27018
- "ePHI safeguards" -> HIPAA Security Rule
- "investors, 2002, 11 titles" -> SOX
- "circumvention of protection measures" -> DMCA
- "federal agencies, NIST" -> FISMA
- "25 May 2018, EU" -> GDPR
- "UK, replaces 1998 act" -> DPA 2018

8.2 Must-memorize lists

1. Five elements: Confidentiality, Integrity, Availability, Authenticity, Non-repudiation.
2. Five attack classes: Passive, Active, Close-in, Insider, Distribution.
3. Five CEH phases: Reconnaissance, Scanning, Gaining access, Maintaining access, Clearing tracks.
4. Seven Kill Chain steps: Recon, Weaponization, Delivery, Exploitation, Installation, C2, Actions on objectives.
5. Four Diamond features: Adversary, Capability, Infrastructure, Victim.
6. Four adaptive security approaches: Protect, Detect, Respond, Predict.
7. Five risk management phases: Identification, Assessment, Treatment, Tracking, Review.
8. Four CTI types: Strategic, Tactical, Operational, Technical.
9. Five TI lifecycle steps: Planning and direction, Collection, Processing and exploitation, Analysis and production, Dissemination and integration.
10. Five threat modeling steps: Objectives, Overview, Decompose, Threats, Vulnerabilities.
11. Nine IH&R steps: Preparation, Recording and assignment, Triage, Notification, Containment, Evidence and forensics, Eradication, Recovery, Post-incident.
12. Seven GDPR principles: Lawfulness/fairness/transparency, Purpose limitation, Data minimization, Accuracy, Storage limitation, Integrity/confidentiality, Accountability.

8.3 Numbers and defaults

Item	Value
Elements of information security	5
Attack classes	5
CEH hacking phases	5
Cyber Kill Chain steps	7
MITRE ATT&CK Enterprise tactics	14
Diamond Model core features	4
IA processes on slide	8
AI-driven ethical hacking benefits	10

Item	Value
AI/ML attack prevention areas	10
IH&R steps	9
PCI DSS goals / requirements	6 / 12
HIPAA rules on slide	5
SOX year / titles	2002 / 11
DMCA treaties	Two 1996 WIPO treaties
GDPR effective date / principles	25 May 2018 / 7
DPA 2018 effective date	25 May 2018
Risk matrix probability bands	1-20, 21-40, 41-60, 61-80, 81-100
ShellGPT config file	~/.config/shell_gpt/.sgptrc

8.4 "Pick the BEST option" rules for this module

1. Before any test, the best first step is getting written authorization and agreeing scope.
2. If a scenario says "without permission", the actor is not a white hat, even if the intent is good.
3. If two attack classes fit, choose the one that explains the key detail (physical presence -> close-in; trusted access -> insider).
4. For kill chain questions, pick the earliest step that matches the action described.
5. For incident questions, contain before you eradicate, and collect evidence before you wipe.
6. For CTI questions, match the audience first (executives -> strategic, SOC analysts -> technical).
7. For law questions, match the data type: cards -> PCI DSS, health -> HIPAA, finance reports -> SOX, EU personal data -> GDPR, federal systems -> FISMA, copyright -> DMCA.
8. For AI questions, the best practice is to verify AI output and protect data and API keys.
9. Defense in depth is the best answer when the question asks how to survive one control failing.

9. Practice Questions

These are original practice questions written for this guide. They are not real exam questions.

Q1. A manager signs a purchase order with her digital signature. A month later she claims she never approved it. The company proves she did using the signature and logs. Which element of information security made this proof possible?

- A. Confidentiality
- B. Availability
- C. Non-repudiation
- D. Integrity

Q2. An attacker connects a laptop to a hub in a branch office and silently records all traffic for a week. No packets are modified or injected. Which class of attack is this?

- A. Active attack
- B. Passive attack
- C. Distribution attack
- D. Insider attack

Q3. A batch of routers ordered by a government department is intercepted during shipping, and modified firmware is loaded before delivery. Which class of attack does this describe?

- A. Close-in attack
- B. Insider attack
- C. Distribution attack
- D. Active attack

Q4. A security researcher, not hired by anyone, finds an SQL injection flaw on an online retailer's site. She does not exploit it further or ask for money, but emails the details to the retailer and posts a vague tweet about it. Which hacker class best fits her?

- A. Gray hat
- B. White hat
- C. Black hat
- D. Blue hat

Q5. A software vendor hires an outside security consultant to test its new mobile banking app two weeks before public release. The consultant has a signed contract. Which hacker class is this consultant?

- A. Red hat
- B. Blue hat

- C. Green hat
- D. Gray hat

Q6. A group defaces a ministry website with messages protesting a new law and leaks internal emails to embarrass the government. They do not target power or water systems. Which class best describes the group?

- A. Cyber terrorists
- B. State-sponsored hackers
- C. Script kiddies
- D. Hacktivists

Q7. During an authorized test, the tester demonstrates that she could delete the Windows Security event log on a compromised server to hide her activity. Which CEH hacking phase does this demonstrate?

- A. Maintaining access
- B. Clearing tracks
- C. Gaining access
- D. Scanning

Q8. An attacker combines an exploit for a document reader with a backdoor into a single malicious PDF. The file has not yet been sent to anyone. Which Cyber Kill Chain phase is this?

- A. Weaponization
- B. Delivery
- C. Exploitation
- D. Installation

Q9. After infection, a workstation sends small HTTPS requests every 60 seconds to an attacker-controlled domain to receive new instructions. Which Cyber Kill Chain phase does this traffic show?

- A. Actions on objectives
- B. Installation
- C. Delivery
- D. Command and control

Q10. A threat analyst starts from a malicious IP address found in firewall logs and pivots to discover which malware used it and which other organizations it contacted. In the Diamond Model, the IP address is an example of which feature?

- A. Capability
- B. Adversary
- C. Victim
- D. Infrastructure

Q11. A security team wants a globally accessible knowledge base of adversary tactics and techniques, based on real-world observations, to map its detection rules against. Which resource should it use?

- A. Cyber Kill Chain
- B. Diamond Model of Intrusion Analysis
- C. MITRE ATT&CK
- D. ISO/IEC 27005

Q12. The board of directors asks for a report on how ransomware and regulatory trends will affect the company over the next three years. Which type of threat intelligence should be provided?

- A. Strategic
- B. Technical
- C. Operational
- D. Tactical

Q13. A SOC analyst receives a feed of malicious file hashes, IP addresses, and domains to load into the SIEM for automatic blocking. Which type of threat intelligence is this?

- A. Tactical
- B. Strategic
- C. Technical
- D. Operational

Q14. In the threat intelligence lifecycle, the team converts collected raw logs, forum posts, and PDF reports into a structured format so analysts can work with them. Which phase is this?

- A. Collection
- B. Analysis and production
- C. Dissemination and integration
- D. Processing and exploitation

Q15. An analyst confirms ransomware on a file server. The incident has been recorded, triaged as critical, and management has been notified. What is the BEST next step?

- A. Reimage the server immediately to remove the malware
- B. Isolate the server from the network to stop the spread
- C. Restore all files from last night's backup
- D. Write the lessons-learned report

Q16. In the continual/adaptive security strategy, which approach includes attack surface analysis and threat intelligence?

- A. Protect
- B. Detect

- C. Respond
- D. Predict

Q17. Using the example risk matrix from this module, a risk has a 70 percent probability and a Major consequence. What is its risk level?

- A. High
- B. Medium
- C. Extreme
- D. Low

Q18. In risk management, which phase estimates the likelihood and impact of the organization's risks?

- A. Risk identification
- B. Risk treatment
- C. Risk assessment
- D. Risk review

Q19. A security vendor trains a model with 100,000 emails, each labeled "phishing" or "legitimate", so the model can label new emails. Which ML approach is this?

- A. Unsupervised learning using clustering
- B. Supervised learning using classification
- C. Unsupervised learning using dimensionality reduction
- D. Supervised learning using regression

Q20. A start-up launches an online shop that accepts debit and credit card payments directly on its site. Which standard must it comply with to keep its card processing privileges?

- A. HIPAA
- B. SOX
- C. PCI DSS
- D. FISMA

Q21. A cloud provider wants to follow a code of practice specifically for protecting personally identifiable information in public clouds. Which standard fits BEST?

- A. ISO/IEC 27018
- B. ISO/IEC 27001
- C. ISO/IEC 27701
- D. ISO/IEC 27005

Q22. Which HIPAA rule specifies administrative, physical, and technical safeguards to ensure the confidentiality, integrity, and availability of electronically protected health information?

- A. Privacy Rule
- B. Enforcement Rule
- C. National Identifier Requirements
- D. Security Rule

Q23. A company that serves EU customers keeps every closed customer account forever "in case it becomes useful". Which GDPR principle does this MOST directly violate?

- A. Accuracy
- B. Storage limitation
- C. Accountability
- D. Lawfulness, fairness, and transparency

Q24. On a Parrot Security machine, a tester types "sudo su", enters a password, and the prompt changes from "$" to "#". What does this mean?

- A. The tester is now working as the root user
- B. The tester has logged out of the system
- C. The tester has connected to a remote host over SSH
- D. The tester is now in a restricted shell

Q25. A tester wants ShellGPT to generate a Linux command and then offer to Execute, Describe, or Abort it. Which option should she use?

- A. -c
- B. -d
- C. -s
- D. --repl

Q26. A tester runs sgpt for the first time and is asked to enter something before it will work. What is ShellGPT asking for?

- A. A Parrot OS license key
- B. The root password of the target
- C. An Nmap license file
- D. An OpenAI API key

Q27. During an authorized test, a junior tester wants to paste the client's full customer database into a public AI chatbot to look for weak passwords. What is the BEST action?

- A. Paste the data, because the test is authorized
- B. Do not send confidential client data to a public AI service without approval; use approved, local, or anonymized methods

- C. Use WormGPT instead, because it has no filters
- D. Paste only half of the database to reduce risk

Q28. An investigator finds that a criminal forum sells access to an AI chatbot without safety filters, advertised for writing business email compromise messages and malware. Which tool fits this description?

- A. WormGPT
- B. PentestGPT
- C. ShellGPT
- D. Bug Hunter GPT

Q29. Which benefit of AI-driven ethical hacking is shown when a system automatically changes its firewall rules as new attack patterns appear?

- A. Adaptive defense mechanisms
- B. Enhanced reporting
- C. Predictive analysis
- D. Scalability

Q30. Which statement describes a limitation of ethical hacking?

- A. It guarantees that the network can no longer be breached
- B. It replaces the need for regular patching
- C. It removes the need for an information security policy
- D. The organization itself must put the right safeguards in place after the test

Answer Key

Q1. C. Non-repudiation means the signer cannot deny the action. A: confidentiality is about secrecy. B: availability is about uptime. D: integrity shows the order was not changed, but the question is about denying.

Q2. B. Recording without changing anything is passive. A: active attacks change or disrupt. C: distribution is tampering before installation. D: nothing says the attacker is a trusted insider.

Q3. C. Tampering with hardware in transit before installation is a distribution attack. A: close-in needs physical nearness to the victim's system. B: no trusted employee is involved. D: active attacks target data in transit on a network, not hardware in shipping.

Q4. A. No permission plus reporting is gray hat. B: white hats are authorized. C: black hats exploit for harm or money. D: blue hats are hired before a release.

Q5. B. An outside tester hired before release is a blue hat. A: red hats attack black hats. C: green hats are learners. D: gray hats lack permission.

Q6. D. A political cause with defacing and leaks is hacktivism. A: cyber terrorists aim for fear and damage to critical infrastructure. B: nothing points to a government sponsor. C: script kiddies act for thrill, not a cause.

Q7. B. Hiding activity by deleting logs is clearing tracks. A: maintaining access is about keeping entry (backdoors). C: access was already gained. D: scanning happens before access.

Q8. A. Building the payload with exploit and backdoor is weaponization. B: nothing was sent yet. C: no code has run on the victim. D: no malware is installed yet.

Q9. D. Regular callbacks for instructions are command and control. A: actions on objectives is reaching the goal (for example, theft). B: installation already happened. C: delivery is sending the payload.

Q10. D. The IP is what the adversary used to reach the victim: infrastructure. A: capability is the malware or method. B: adversary is who. C: victim is the target.

Q11. C. MITRE ATT&CK is the knowledge base from real-world observations. A: the Kill Chain is a 7-stage model, not a technique catalogue. B: the Diamond Model analyzes intrusion events. D: ISO 27005 is risk management guidance.

Q12. A. Executives and long-term trends mean strategic. B: technical is IoCs. C: operational is a specific incoming attack. D: tactical is TTPs for SOC managers.

Q13. C. Hashes, IPs, and domains are IoCs: technical. A: tactical is TTPs. B: strategic is high-level. D: operational is details of a specific attack.

Q14. D. Converting raw data into usable format is processing and exploitation. A: collection gathers it. B: analysis produces the finished intelligence. C: dissemination delivers it.

Q15. B. After notification comes containment. A: eradication comes after containment and evidence gathering. C: recovery comes after eradication. D: documentation is post-incident.

Q16. D. Attack surface analysis and threat intelligence are under Predict. A: protect is defense-in-depth. B: detect is continuous monitoring. C: respond is incident response.

Q17. A. The 61-80 percent row (High probability) with Major consequence gives High. B, C, D do not match that cell; Extreme appears only for Severe in that row.

Q18. C. Risk assessment estimates likelihood and impact. A: identification finds sources and causes. B: treatment picks controls. D: review evaluates performance.

Q19. B. Labeled data with categories is supervised classification. A and C: unsupervised uses unlabeled data. D: regression predicts numbers, not labels.

Q20. C. Card payments require PCI DSS. A: HIPAA is health data. B: SOX is public company financial reporting. D: FISMA is US federal systems.

Q21. A. ISO/IEC 27018 covers PII in public clouds. B: 27001 is ISMS requirements. C: 27701 is privacy management extending 27001, not cloud-specific. D: 27005 is risk management.

Q22. D. The Security Rule specifies the three safeguard types for ePHI. A: the Privacy Rule covers patient rights over PHI. B: the Enforcement Rule covers enforcement. C: identifiers are about standard numbers.

Q23. B. Keeping data longer than needed breaks storage limitation. A: accuracy is about correct data. C: accountability is about proving compliance. D: lawfulness is about a legal basis and transparency.

Q24. A. "#" shows a root shell after sudo su. B: the session is still open. C: no SSH was used. D: root is the least restricted user.

Q25. C. -s (--shell) generates commands with the Execute, Describe, Abort menu. A: -c outputs code only. B: -d describes a command you give it. D: --repl starts an interactive chat.

Q26. D. ShellGPT needs an OpenAI API key. A: Parrot OS has no license key. B: it never asks for target passwords. C: Nmap has no license file.

Q27. B. Protect client data; get approval and use safe methods. A: authorization to test does not allow sharing data with third parties. C: WormGPT is a criminal tool. D: half the data is still a breach.

Q28. A. WormGPT is a malicious LLM sold for BEC and malware. B, C, D are tools for ethical hacking support.

Q29. A. Defenses that change automatically are adaptive defense mechanisms. B: reporting is documentation. C: predictive analysis forecasts. D: scalability is handling size.

Q30. D. The slide says the organization must place the right safeguards. A, B, C are false claims; ethical hacking never guarantees security or replaces patching and policy.

10. Flashcards

- Q: What are the five elements of information security? | A: Confidentiality, integrity, availability, authenticity, non-repudiation.
- Q: Which element guarantees a sender cannot deny sending a message? | A: Non-repudiation.
- Q: What is the attack formula? | A: Attack = Motive (Goal) + Method (TTP) + Vulnerability.
- Q: What does TTP stand for? | A: Tactics, techniques, and procedures.
- Q: Which TTP element is the strategy from beginning to end? | A: Tactics.
- Q: Name the five attack classes. | A: Passive, active, close-in, insider, distribution.
- Q: Sniffing and eavesdropping are which attack class? | A: Passive.
- Q: Shoulder surfing and dumpster diving are which attack class? | A: Close-in.
- Q: Tampering with hardware before installation is which attack class? | A: Distribution.
- Q: What is information warfare? | A: Using ICT to gain a competitive advantage over an opponent.
- Q: Is deterrence defensive or offensive information warfare? | A: Defensive.
- Q: Which hacker finds flaws without permission but may report them? | A: Gray hat.
- Q: Which hacker is hired to test a product before release? | A: Blue hat.
- Q: Which hacker is a vigilante targeting black hats? | A: Red hat.
- Q: Which hacker is a newcomer eager to learn? | A: Green hat.
- Q: Which hackers use pre-made tools without understanding them? | A: Script kiddies.
- Q: What is a key limitation of ethical hacking? | A: The organization must put the right safeguards in place itself.
- Q: What does ShellGPT need on first run? | A: An OpenAI API key.
- Q: Which sgpt flag generates shell commands? | A: -s or --shell.
- Q: Name the five CEH hacking phases. | A: Reconnaissance, scanning, gaining access, maintaining access, clearing tracks.
- Q: Name the eight ethical hacking domains on the framework slide. | A: System, web app, network, mobile, wireless, OT/IoT, cloud, hacking AI.
- Q: Name the seven Cyber Kill Chain phases. | A: Recon, weaponization, delivery, exploitation, installation, command and control, actions on objectives.
- Q: How many tactics are in MITRE ATT&CK for Enterprise? | A: 14.
- Q: Which kill chain stages map to PRE-ATT&CK on the slide? | A: Recon and weaponize.
- Q: What are the four Diamond Model features? | A: Adversary (who), victim (where), capability (how), infrastructure (what).
- Q: What is the atomic element of the Diamond Model called? | A: The Diamond event.

- Q: Name the four adaptive security approaches. | A: Protect, detect, respond, predict.
- Q: Name the five risk management phases. | A: Identification, assessment, treatment, tracking, review.
- Q: Who consumes strategic threat intelligence? | A: High-level executives and management.
- Q: What does technical threat intelligence contain? | A: Indicators of compromise.
- Q: Name the five threat intelligence lifecycle phases. | A: Planning and direction, collection, processing and exploitation, analysis and production, dissemination and integration.
- Q: What is MASINT? | A: Measurement and signature intelligence.
- Q: Which threat modeling step identifies components, data flows, and trust boundaries? | A: Application overview.
- Q: Which IH&R step comes right after notification? | A: Containment.
- Q: Clustering belongs to which ML type? | A: Unsupervised learning.
- Q: How many PCI DSS high-level goals are there? | A: Six.
- Q: Which ISO standard specifies ISMS requirements? | A: ISO/IEC 27001.
- Q: When was SOX enacted and how many titles does it have? | A: 2002, 11 titles.
- Q: Which law implements two 1996 WIPO treaties? | A: DMCA.
- Q: When did GDPR take effect? | A: 25 May 2018.

11. Glossary

- Accountability (GDPR): the controller must prove compliance with all principles.
- Accreditation: management approval to operate a system after certification.
- Actions on objectives: final kill chain phase where the attacker reaches the goal.
- Active attack: an attack that changes data or disrupts services.
- Adaptive security strategy: continuous cycle of protect, detect, respond, predict.
- Adversary: in the Diamond Model, who is behind the attack.
- API key: secret token that lets a program use an online service.
- Attack surface: all points where an attacker could try to get in.
- Authenticity: the quality of being genuine.
- Availability: systems are accessible when authorized users need them.
- Backdoor: hidden way into a system that bypasses normal login.
- Black hat: malicious hacker acting for money or harm.
- Blue hat: outside tester hired before a product release.
- Botnet: network of infected machines controlled by an attacker.
- Burp Suite: web proxy for intercepting and testing web traffic.
- Capability: in the Diamond Model, how the attack was performed.
- Certification: technical evaluation that a system meets security requirements.
- ChatGPT: OpenAI's large language model chat service.
- Clearing tracks: final CEH phase of hiding evidence.
- Close-in attack: attack by someone physically near the target.
- Clustering: unsupervised grouping of similar data.
- Command and control (C2): channel between attacker and infected host.
- Confidentiality: only authorized people can access information.
- Containment: IH&R step that stops an incident from spreading.
- Corporate spy: person hired to steal a competitor's information.
- Cryptanalysis: analyzing or breaking encryption.
- Cyber Kill Chain: Lockheed Martin's 7-phase intrusion model.
- Cyber terrorist: extremist using cyber attacks to spread fear.
- Cyber threat intelligence (CTI): analyzed information about threats used for decisions.
- Data minimization: collect only the data you need.
- Decompose (threat modeling): break an application into parts to find threats.
- Deepfake: AI-generated fake audio or video of a real person.
- Defense-in-depth: multiple layers of security controls.
- Diamond event: atomic unit of activity in the Diamond Model.
- Diamond Model: intrusion analysis model of adversary, capability, infrastructure, victim.
- Dimensionality reduction: reducing many data features to the key few.
- Distribution attack: tampering with hardware or software before installation.
- DMCA: US copyright law against circumventing protection measures.

- Dumpster diving: searching rubbish for useful information.
- Eavesdropping: secretly listening to communications.
- Endpoint: user or server device on a network.
- Eradication: IH&R step that removes the cause of an incident.
- Ethical hacking: authorized hacking to find and fix weaknesses.
- Exploit: code that takes advantage of a vulnerability.
- FISMA: US law for security of federal information systems.
- GDPR: EU privacy regulation effective 25 May 2018.
- Gray hat: hacker who tests without permission, sometimes reporting flaws.
- Green hat: newcomer learning hacking.
- Hacking: exploiting vulnerabilities to gain unauthorized access.
- Hacktivist: hacker driven by a political or social cause.
- HIPAA: US law protecting health information.
- HUMINT: intelligence from human sources.
- IMINT: intelligence from imagery.
- Incident handling and response (IH&R): organized steps to handle security incidents.
- Indicator of compromise (IoC): artifact showing a system was attacked.
- Information assurance (IA): protecting CIA and authenticity of information in all states.
- Information warfare: using ICT to gain advantage over an opponent.
- Infrastructure: in the Diamond Model, what the adversary used to reach the victim.
- Insider attack: attack by a trusted person abusing access.
- Integrity: data is trustworthy and not changed without authorization.
- ISMS: management system for information security (ISO 27001).
- Keylogger: tool that records keystrokes.
- LGPD: Brazil's general data protection law.
- LLM: large language model, AI trained on huge text data.
- Machine learning (ML): systems that learn patterns from data.
- MASINT: measurement and signature intelligence.
- Metasploit: framework for running exploits and payloads.
- MITM: attacker secretly relays or alters communication between two parties.
- MITRE ATT&CK: knowledge base of adversary tactics and techniques.
- Nmap: network scanner for hosts, ports, and services.
- Non-repudiation: sender and receiver cannot deny the exchange.
- OSINT: intelligence from public sources.
- Passive attack: attack that monitors without changing data.
- Payload: malicious code that performs the harmful action.
- PCI DSS: security standard for cardholder data.
- PentestGPT: AI tool that guides penetration testing.
- PII: personally identifiable information.
- PIPEDA: Canada's private-sector privacy law.
- Privilege escalation: gaining higher rights than granted.
- Procedures: systematic step-by-step approach of a threat actor.

- Prompt injection: crafted input that makes an LLM ignore its instructions.
- Reconnaissance: gathering information about a target.
- Red hat: vigilante hacker attacking black hats.
- Regression: supervised ML that predicts a number.
- Risk matrix: grid of likelihood versus consequence.
- Risk: uncertainty that an adverse event may cause damage.
- Root: the Linux administrator account.
- Script kiddie: unskilled attacker using others' tools.
- Session hijacking: taking over a user's active session.
- SET: Social-Engineer Toolkit for social engineering attacks.
- ShellGPT (sgpt): AI assistant used in the command line.
- Shoulder surfing: watching someone enter secrets.
- Sniffing: capturing network packets.
- SOX: US law for accurate public company financial reporting.
- SQL injection: inserting database commands into input.
- State-sponsored hacker: hacker working for a government.
- Supervised learning: ML trained with labeled data.
- Tactics: attacker's overall strategy.
- Techniques: technical methods for intermediate results.
- Threat modeling: risk approach to analyze an application's security.
- Triage: sorting incidents by severity.
- Trust boundary: line where data crosses between trust levels.
- Unsupervised learning: ML trained with unlabeled data.
- Victim: in the Diamond Model, where the attack happened.
- Vulnerability: weakness that can be exploited.
- Weaponization: kill chain phase of building the payload.
- White hat: authorized security professional.
- Wireshark: packet capture and analysis tool.
- WormGPT: malicious LLM tool sold to criminals.

12. Coverage Report

12.1 Page to section map

PDF page	Content in screenshots	Guide section
1	Elements of information security (slide 4)	3.1
1	Motives, goals, objectives (slide 5, plus video frame)	3.2
1	TTPs (slide 6)	3.3
2	Classification of attacks (slide 8)	3.4
2	Information warfare (slide 9)	3.5
3	What is hacking (slide 11)	3.6
3	Who is a hacker (slide 12, video frame)	3.7
4	Hacker classes and motivations (slides 13 and 14)	3.8
5	Scope and limitations (slide 18)	3.9
5	AI-driven ethical hacking benefits (slide 21)	3.10
6	ChatGPT tools and ShellGPT (slide 23, plus video frame)	3.11, 4, 5.1, 5.2
7	CEH ethical hacking framework (slide 28)	3.12, 4, 5.3
7	Cyber Kill Chain (slide 29)	3.13
8	MITRE ATT&CK (slide 30)	3.14
8	Diamond Model (slide 31)	3.15
9	Information assurance (slide 33)	3.16
9	Continual/adaptive security strategy (slide 34)	3.17
10	Risk management (slide 37)	3.18
10	What is risk, levels and matrix (slide 36)	3.19
11	Cyber threat intelligence (slide 38)	3.20
11	Threat intelligence lifecycle (slide 39)	3.21
12	Threat modeling (slide 40, video frame)	3.22
12	Incident handling and response (slide 42)	3.23

PDF page	Content in screenshots	Guide section
13	Role of AI and ML (slide 43)	3.24
13	How AI and ML prevent attacks (slide 44)	3.25
14	PCI DSS (slide 48)	3.26
14	ISO/IEC standards (slide 49)	3.27
15	HIPAA (slide 50)	3.28
15	SOX (slide 51)	3.29
16	DMCA and FISMA (slide 52)	3.30
16	GDPR (slide 53)	3.31
17	DPA 2018 (slide 54)	3.32
17	Cyber law in different countries, cont'd (slide 57)	3.33
18	Module summary (slide 58)	1

12.2 UNCLEAR items

None. All pages were readable. The risk matrix and country law table on pages 10 and 17 use small text; they were read carefully and cross-checked for consistency, but compare them once with the video if a value looks odd.

12.3 Items to double check

- Slide 28 calls Phase 2 "Vulnerability Scanning"; most CEH material says "Scanning". Same phase.
- Slide 30 shows the older PRE-ATT&CK split. Current MITRE ATT&CK includes Reconnaissance and Resource Development as Enterprise tactics.
- Slide 31 labels the relationship diagram "Meta Features". The original Diamond Model meta-features are timestamp, phase, result, direction, methodology, resources.
- Slides not in the screenshots (numbering gaps, for example 7, 10, 15 to 17, 19 to 20, 22, 24 to 27, 32, 35, 41, 45 to 47, 55 to 56) likely cover ethical hacking definition and skills, information security controls, defense-in-depth, and the first page of the cyber law table. ADDED CONTEXT blocks cover the usual content; verify against the videos.
- ShellGPT default model and package details change often; the flag list was checked against the project README.
- Items marked "verify" in the text: Libicki's InfoWar forms in v13, extra hacker classes in v13, attack vector list, ATT&CK technique IDs, risk formula wording, ISO 27002 control count and the 27701 revision, HIPAA encryption safe harbor, Hong Kong Article 139 meaning, first page of the country law table.

12.4 Inventory confirmation

Every line of the page inventory (34 slide entries across 18 PDF pages, including 4 duplicate video frames that were merged) is mapped to exactly one primary section in the table above. All tools (Nmap, Wireshark, Burp Suite, Metasploit, SET, AI, ShellGPT, HackerGPT, PentestGPT, Bug Hunter GPT, h4ckGPT, Ethical Hacker GPT, Parrot Security), both commands (sudo su, sgpt), all acronyms, standards, and laws from the screenshots appear in sections 3 to 6.